ISMS審査 提出資料一覧（個人情報漏えい 机上訓練）

提出資料の一覧・実施概要・主な結果・今後の対応

ISMS審査 提出用 | 実施日 2026-10-02（金）15:00 - 16:00 | 株式会社STANDS

提出日: 2026-10-02
対象: 2026-10-02（金）15:00 - 16:00 に実施した個人情報漏えいインシデントの机上訓練
提出者: 空（訓練の企画・進行・記録）

> **本訓練で扱った不具合は架空のものです。** 実際に発生した事象ではありません。
> 実在の顧客データの漏えいは発生していません。

1. 提出資料

#	資料	内容	位置づけ
1	訓練の概要と準備	実施設定・体制・事前準備の手順	計画
2	ファシリテーター用進行台本	進行手順・投入する情報・観測項目・振り返りの進め方	計画（詳細）
3	Slack投入用テキスト	当日投入した文面の一式	計画（詳細）
4	**訓練実施記録**	時系列51件・測定結果・投票結果	**実施記録**
5	**訓練実施報告**	結果の評価、よくできていたこと、見つかった空白8点	**レビュー**
6	参加者配布資料	訓練後に全参加者へ配布した解説資料（法令の要点を含む）	教育

資料2・3には訓練シナリオの内容が含まれるため、**社内では進行役のみが保持**しています。
審査に際しては、計画の妥当性を確認いただくために提出します。

2. 実施の概要

項目	内容
目的	インシデント対応フローを整備するにあたり、**現状で決められないことを洗い出す**
形式	机上訓練。実システムには一切触れない
実施方法	**Slack完結型。**会議体を設けず、参加者は通常業務と並行して対応
参加者	ISMS管理者・CS・エンジニアを含む11名（投票参加者数）
シナリオ	管理画面のCSVダウンロード機能の不具合により、顧客が取得したCSVに他社データが混入
事前共有	**進行役1名を除き、シナリオは誰にも共有していない**（ISMS管理者を含む）

会議を設けなかった理由: 実際のインシデントは通常業務中にSlackで始まります。
通知に気づくか、片手間で初動が回るかは、会議を設定した訓練では測れないためです。

---

3. 主な結果

項目	結果
第一報 → 最初の反応	約2分
第一報 → ISMS管理者へ到達	約10分
原因特定から修正リリースまで（止血）	**48分**
実システムへの接触	なし（ルールどおり）
顧客との共有チャンネルへの社内議論の流出	1回（注意後は発生せず）

初動と止血は速く、影響範囲についても「指摘してきた1社」に閉じず、
閲覧された側の顧客まで対象になるという点に、誘導なしで到達しています。

一方で、以下が決まっていないことが確認されました（詳細は資料5）。

#	見つかった空白
1	インシデント専用チャンネルの運用（今回は作られず、既存3チャンネル5スレッドに分散）
2	**証跡保全の手順**（指示が誰からも出なかった）
3	委託／自社取得の契約上の整理（報告主体の判断に直結。混入元への通知方針が未決）
4	機能の一時停止の判断権限
5	扱うデータ項目の個人情報該当性の整理
6	顧客への連絡文面のテンプレート
7	音声へ切り替える基準と、決定の書き戻しルール
8	**調査体制**（依頼は2名宛だったが、実際に動いたのは1名。役割を分けるルールがない）

---

4. 今後の対応

見つかった空白は、担当と期限を付けたアクションとして管理を開始しています（12件）。

現時点では担当・期限の割り当てが完了していないため、本提出資料には含めていません。
進捗および今後の計画については、**審査時に口頭でご報告します。**

予定している対応	概要
対応フローの整備	上記の空白1〜8を章立てとしたドラフトを作成し、関係者レビューを経て確定
技術面の点検	集計処理のリリース前チェック、操作ログの保全状況の確認
確認方法	**訓練の再実施は行わず**、ドラフトの関係者レビューで確認

技術面の点検は、**今回の不具合が架空である**ことから「再発防止」ではなく
「同じことが起こり得る箇所の未然点検」として扱います。

---

5. 参考：関連する管理策

本訓練および今後の対応が関係すると考えている管理策です。
最終的な対応付けは ISMS管理者の判断によります。

管理策	本訓練との関係
A.5.24 情報セキュリティインシデント管理の計画及び準備	対応フローが未整備であることの確認と、整備の着手
A.5.25 情報セキュリティ事象の評価及び決定	「疑い」の段階で上げる判断、報告対象かどうかの判断
A.5.26 情報セキュリティインシデントへの対応	初動・調査・止血・顧客連絡の一連の実施
A.5.27 情報セキュリティインシデントからの学習	訓練結果の分析と、アクションへの変換
A.5.34 プライバシー及びPIIの保護	個人情報保護法上の報告義務・該当者への通知の検討
A.6.3 情報セキュリティの意識向上、教育及び訓練	全参加者への配布資料による教育、無罰ルールの周知

個人情報漏えい 机上訓練

資料の構成・実施設定・事前準備

社内資料 | 実施日 2026-10-02（金）15:00 - 16:00 | 株式会社STANDS

管理画面のログインレポートCSVダウンロード機能の不具合で、顧客が自分でダウンロードしたCSVに
他社プロダクトのデータが混入していた、という想定で行う60分の机上訓練一式。
実システムには一切触らない。主催側からは会議を設定せず、すべてSlackで行う。

成果物は「うまく対応できたかの評価」ではなく「決められなかったことのリスト」。
当社には対応フローも CSIRT 相当の組織も無いため、この訓練は
フローに何を書くべきかを洗い出す要件定義として実施する。参加者が詰まるほど成功。

> **取扱注意**: 進行台本と Slack投入用テキストは**ファシリテーターのみ**が持つ。
> 参加者に渡してよいのは、訓練終了後の**参加者配布資料だけ**。

ファイル

ファイル	何のためのものか	持つ人	使うタイミング
00_訓練の概要と準備.pdf（本書）	この索引。決定事項と進め方の入口	全員	最初に読む
01_ファシリテーター用進行台本.pdf	**進行台本。まずこれを読む。** 事前準備・役割・タイムテーブル・各インジェクトの投げる問いと誘導セリフ・振り返りの進め方・訓練後の宿題まで	ファシリテーターのみ	準備〜当日〜事後
02_Slack投入用テキスト.pdf	**Slackにコピペする文面集。** 当事者役へのDM・第一報・集計結果・投票・続報・ネタバラシ、および参加者の返信に対する応答パターン集	ファシリテーターのみ	当日、手元に開いておく
2026-09-07_incident-drill-retrospective-sheet.xlsx	**記入用の振り返り／チェックシート（Excel）。** 時系列・測定値・集約・確認漏れチェック・アクション化	記録係・ファシリテーター	訓練中〜訓練後
2026-10-02_action-plan.md	**アクション管理。** 見つかった空白を担当・期限付きのアクションに変換して追跡する。**担当と期限はこれが正**	ファシリテーター	訓練後〜フロー確定まで
04_訓練実施報告.pdf	**実施報告。** 測定結果・よくできていたこと・見つかった空白8点・今後の予定	参加者全員	訓練終了後に配布
2026-10-02_post-drill-survey-form.md	**訓練後アンケート（Googleフォーム）のテンプレート。** 設問一覧・Apps Script・回答後の集約手順	ファシリテーター	訓練終了後
03_参加者配布資料.pdf	**参加者配布資料。** 各場面の正解に近い動き・個人情報保護法の要点・やりがちな失敗・明日からのお願い	参加者全員	**訓練終了後に**配布

Excel シートの中身

シート	記入する人	タイミング
表紙・実施概要	ファシリテーター	事前
Part1 時系列・測定値	記録係	訓練中はSlackに残らないものだけメモ、残りは終了後に復元
Part2 確認漏れチェック	ファシリテーター	アンケートの集約後

xlsx が持つのはこの2つだけ。**個人記入とその集約は Googleフォームの回答スプレッドシート**、**アクション（担当・期限・状態）は** `2026-10-02_action-plan.md` で管理する。

今回の実施設定

項目	決定
実施モード	**モードC（Slack完結型）** — **主催側からは会議を設定しない。** 開始・終了ともSlackで告知し、振り返りもスレッドで完結（参加者が自分でハドルを立てるのは自由）
抜き打ち度	予告あり（「◯時から1時間、机上訓練をやります。こちらからは会議を設定しません」とだけ伝える）
所要時間	60分（インジェクト⑤を足す75分版あり）
訓練用チャンネル	`#2026_個人情報漏えい訓練`（トピックに `【訓練用】ONBS-1998 机上訓練専用`）。**A社との共有チャンネル想定であることを開始告知で明示する**
社内対応チャンネル	**あえて用意しない。** 参加者が自分で作るかが観測点
実施日時	**2026-10-02（金）15:00 - 16:00**

役割	担当
ファシリテーター（A社 田中さん役 / 記録係 兼任）	空 ／ **対応メンバーとしては「休暇で不在」の設定**
統括判断者	藤原（ISMS管理者）／ **シナリオを知らない訓練対象**（事前共有しない）
一次受け	椎名（CS）
調査担当	鈴木（エンジニア・**改修した本人役**）／ 文（エンジニア・**役の情報なし**）
（分担）	**割り当てない。** 誰が事実確認を引き取るかは観測点
オブザーバー	経営層1名（可能なら）・未定

進め方

いつ	やること	見るファイル
～10/1（木）	参加者へ案内（9/30まで）、チャンネル作成。**シナリオは誰にも事前共有しない**	台本「§2 事前準備」
10/2 14:50頃	鈴木さんへDMで役の情報を渡す	投入テキスト「開始直前 — 鈴木さんへのDM」
15:00	**Slackへ開始告知**（`@channel`。無罰宣言を含む）	投入テキスト「オープニング告知」
15:05～15:47	時刻どおりにSlackへインジェクト①～④を投入し、あとは観測（15:05 / 15:15 / **15:26** / 15:41）	投入テキスト ＋ 台本「§6 当日の流れ」
15:47	**スレッドで振り返り**（下書き → 一斉投稿 → その場で集約）	台本「§5 振り返り」
15:58	クロージングを投稿 → **配布資料とネタバラシを投稿**	配布資料 ＋ 投入テキスト
訓練後	集約をアクションに変換、チャンネルをアーカイブ	`2026-10-02_action-plan.md` ＋ 台本「§9」

事前準備（カレンダー登録用）

すべて台本 01_ファシリテーター用進行台本.pdf の「§2 事前準備」が出典。
文面が要るものは 02_Slack投入用テキスト.pdf にある。

期日	やること	担当	記載場所
～9/30（水）	**オブザーバー（経営層1名）を確保する**（可能なら）	空	台本 §2「前日までに」／§2「役割の割り当て」
9/30（水）	参加者へ案内を送る（「10/2 15:00～16:00 / 予習不要 / 会議は設定しない / Slackを見られる状態に」のみ）	空	台本 §2「前日までに」
9/30（水）	**シナリオは誰にも事前共有しない**（藤原さんも訓練の対象）。停止権限は空さんが持つ。オブザーバーを置ける場合のみ、その人にだけ共有する	空	台本 §2「前日までに」／投入テキスト「⚠️ 実施前に必ず読むこと」
10/1（木）	`#2026_個人情報漏えい訓練` を作成、**トピックに `【訓練用】ONBS-1998 机上訓練専用`**、参加者全員を招待	空	台本 §2「チャンネル構成」／投入テキスト「チャンネル構成」
—	~~canvas を作る~~ **不要。** 共有チャンネルに社内の時系列を貼らない。時系列は xlsx の Part1 へ	—	台本 §2「チャンネル構成」
10/1（木）	開始告知・クロージングの文面を用意し、インジェクト文面をコピペできる状態にしておく	空	投入テキスト 全体
10/2（金）14:45	**鈴木さんへDM**で役の情報を渡す（他の参加者には見せない）	空 → 鈴木	台本 §2「当日、開始前に」／投入テキスト「開始直前 — 鈴木さんへのDM」
10/2（金）14:50	全体チャンネルへ**訓練実施の周知**を投稿（既存チャンネルでのやり取りも起きる旨を含む）	空	投入テキスト「参加していないメンバーへの周知」
10/2（金）14:55	振り返りシート（xlsx）を開く。**配布資料はまだ投稿しない**	空	台本 §2「当日、開始前に」

社内対応用チャンネルは作らない。 参加者が自分で作るかどうかが観測点。

> 事前に読んでおくもの: 投入テキスト冒頭の「⚠️ 実施前に必ず読むこと」（厳守事項5点）と、
> 台本 §6「モードC（Slack完結型）の運用」。当日はこの2つが手元にあれば回せる。

シナリオの登場企業

呼び方	立場
A社	CSVを受け取り、混入を指摘してきた取引先
他社プロダクト3社	A社のCSVに混入していた、**データの持ち主**である顧客企業。各資料の「3社」はこれ
計5社	同じ期間に同じログインレポートをダウンロードした顧客（A社を含む）。**残り4社分は中身が未確定**という設定
B社	上記3社のうちの1社。インジェクト⑤で「A社経由で先に知った」として問い合わせてくる。**同じチャンネルへ投稿するため、直前に「場面転換アナウンス」を挟んで読み替える**（チャンネルは増やさない）
鈴木さんの役	**該当の集計ロジックを先月改修したエンジニア。**まだ自分の改修が原因だと結び付いていない
1,240名	3社のエンドユーザー。情報が漏えいした**該当者**（法律上の「本人」）。**報告件数は行数（48,000行）ではなくこちら**

守ること

- **実際のクライアントとのSlackチャンネル（Slack Connect含む）には絶対に投稿しない**
- 台本と投入テキストを参加者に渡さない。配布してよいのは終了後の配布資料だけ
- **訓練は必ずその日のうちに終了させ、ネタバラシまで行う**
- 参加者が本物のクライアントや社外に連絡しようとしたら、**即座に訓練であることを明かして止める**
- 訓練用チャンネルは**削除ではなくアーカイブ**する（訓練記録として残す）

個人情報漏えい 机上訓練 ファシリテーター用進行台本（リモート / Slack版）

準備から当日の進行・振り返りまでの手順

取扱注意 ／ ファシリテーターのみ | 実施日 2026-10-02（金）15:00 - 16:00 | 株式会社STANDS

シナリオ: 管理画面の**ログインレポートCSVダウンロード機能**の不具合により、顧客が自分でダウンロードしたCSVに**他社プロダクトのデータが混入**。顧客からの指摘で発覚する
実施日時: **2026-10-02（金）15:00 - 16:00**
所要時間: 60分（オプション込み75分）
実施環境: 全員リモート。**開始・終了の告知も情報投入もすべてSlack。主催側からは会議（Meet / ハドル）を立てない**
形式: 机上訓練（ロールプレイ＋ディスカッション）。実システムには一切触れない

> **取扱注意**: この文書はファシリテーターのみが持つ。参加者には訓練終了まで開示しない。
> 終了後は 03_参加者配布資料.pdf を配布する。
>
> **架空の不具合であることを、開始告知で必ず明示する。** 自社の実在機能を題材にするため、
> 参加者が本番の管理画面やコードを調べ始めるおそれがある。
> 「実際にこの不具合は存在しません。本番・コードは見ないでください」と最初に書く。

---

0. この訓練の設計思想

成果物は「うまくできたかの評価」ではなく「決められなかったことのリスト」。

当社にはまだ対応フローが存在せず、CSIRT相当の組織もない。したがってこの訓練は
「フロー通りに動けるか」のテストではなく、**フローに何を書くべきかを洗い出す要件定義**である。

参加者が詰まるほど成功。ファシリテーターは正解を配らず、詰まった箇所を記録係に確実に拾わせる。

リモート / Slack環境だからこそ検証できること

当社は全員リモートで、実際のインシデントもSlack上で始まりSlack上で処理される。
したがって**訓練をSlackで行うことは「本番の再現」そのもの**であり、以下が追加の観測対象になる。

#	検証したいこと	なぜ
1	音声（ハドル / Meet）を立てたか。立てるまでの時間	文字だけで進めようとすると初動が遅れる。**今回は主催側から会議を立てないため、参加者が自分で立てるかどうかが観測点**
2	社内対応用チャンネルを作ったか	インシデント専用の場を切らないと情報が散る
3	**重要な判断をDMで閉じなかったか**	リモート最大のリスク。DMで決まった判断は記録に残らず、後から追えない
4	非同期の待ち時間に何をしたか	「A社の返信待ち」の間に手が止まるか、並行して動けるか
5	全員が同じ状況認識を持てたか	誰が何を知っているかがバラバラだと二重連絡・矛盾した回答が起きる

共通で炙り出したい5点

#	検証したいこと	なぜ
1	第一報が責任者に届くまでの経路と時間	一報は営業/CSに来る。エンジニアチームには直接来ない
2	「疑い」段階でエスカレーションできるか	確証を待つと初動が数日遅れる
3	「知った時」の時刻を記録する意識	法定報告期限の起点。曖昧だと後で詰む
4	判断者が誰か即答できるか	CSIRTがない現状で最大の空白地帯
5	証跡保全の指示が出るか	調査のためにログを触って上書きするのが典型的事故

---

1. 実施モードの選択

リモート訓練は、**音声をつなぎ続けるかどうか**で難易度と観測できるものが変わる。

> **今回の実施モード: モードC（Slack完結型）** ← 決定済み。**主催側からは会議を設定せず、開始も終了もSlackの告知で行う**
> （参加者が自分でハドルを立てるのは自由。立てるかどうかが観測点）

モード	やり方	観測できること	向いている場面
モードA: 常時接続型	開始から終了までGoogle Meetをつなぎっぱなしにし、Slackへのインジェクトと並行して議論させる	判断の中身。進行が安定する	議論が止まりにくく、ファシリテーターが全部見える
モードB: 解散型	オープニングだけMeetで行い、説明後に解散して各自のデスクに戻す。以降はSlackだけで進行する	招集判断そのもの	全員が冒頭の5分だけなら集まれるとき
モードC: Slack完結型（今回）	**主催側からは会議を設定しない。** 開始も終了もSlackの告知だけで行い、参加者は通常業務の合間に反応する	**通知に気づくか。片手間で初動が回るか。** 本番に最も近い	**全員の時間を押さえられないとき。** 実際のインシデントもこの形で始まる

以降の台本（§5）はモードAの書き方が基準になっている。今回はモードBで運用するため、
読み替えは「§6 モードB（解散型）の運用【今回はこれ】」を先に読むこと。

主催側から会議を設定しないことで起きうること（承知のうえで進める）

全員の時間を1時間押さえるのが難しいため、こちらからは会議を設定しない。 代わりに次が起きる。

起きうること	対処
告知に気づかないまま時間が過ぎる	開始告知は `@channel` で投げ、**終了予定時刻まで書く**。それでも反応が無ければ §6 の催促を使う
反応が飛び飛びになり、議論が深まらない	**インジェクトの投入時刻は動かさない。** 特に③は時刻どおりに投入する
誰も動かない / 一次受けだけが動いて終わる	動かなかったこと自体を発見として記録する。責めない
振り返りの熱量が落ちる（顔を合わせないため）	振り返りはスレッドで完結させ、**ファシリテーターがその場で集約を書き戻す**。後日まとめに回さない
参加率が読めない	事前告知で「この時間帯はSlackを見られる状態にしておいてください」とだけ依頼する。離席は想定内
議論がハドル内で進み、ファシリテーターから見えない	参加者が自分でハドルを立てた場合は**オブザーバーとして入る**。入れなければ「終わったら要点をチャンネルに書いてください」と1回だけ依頼する

> 会議を立てないぶん、**判断の中身は薄くなりやすい。** それでもこの形を採るのは、
> 実際のインシデントが**通常業務中にSlackで始まる**ため、
> **通知に気づくか・片手間で初動が回るかは、会議ありの訓練では測れない。**
> うまく回らないことは想定内であり、それ自体が要件になる。

---

2. 事前準備

チャンネル構成（重要）

2つのうち片方だけを用意する。 これが観測点になる。

チャンネル	用意するか	役割
`#2026_個人情報漏えい訓練`	**ファシリテーターが作る**	A社との共有チャンネル想定。田中さん役として一報を投入する場。参加者全員を招待
社内対応用チャンネル	**あえて用意しない**	参加者が自分で作るかを観測する。作らなければそれが発見

- チャンネルトピックに `【訓練用】ONBS-1998 机上訓練専用` と明記する
- **canvas は作らない。** このチャンネルはA社との共有チャンネル想定なので、
  そこに社内の対応時系列を貼ること自体が、訓練で咎めている行為になる。

時系列は `2026-09-07_incident-drill-retrospective-sheet.xlsx` の Part 1 に一本化し、**終了後に Slack のタイムスタンプから埋める**

前日までに

- [ ] **9/30（水）までに**参加者へ案内を送る。**内容は「10/2（金）15:00〜16:00 で個人情報漏えいの机上訓練をやります。予習不要・資料不要。こちらからは会議を設定しません。この時間帯はSlackを見られる状態にしておいてください」のみ**
- [ ] **シナリオは誰にも事前共有しない。** 藤原さん（ISMS管理者）も今回は訓練の対象。停止権限はファシリテーター（空さん）が持つ。**オブザーバー（経営層）を置ける場合のみ、**その人にだけ事前共有し、暴走時に止められるようにする
- [ ] **オブザーバー（経営層1名）を確保する**（可能なら。未確定）
- [ ] 記録用に `2026-09-07_incident-drill-retrospective-sheet.xlsx` を開けるようにしておく（今回の記録係はファシリテーター兼任。訓練中に書くのは §6「記録の取り方」の3つだけ）
- [ ] `#2026_個人情報漏えい訓練` を作成し、トピックを設定して参加者全員を招待する
- [ ] 02_Slack投入用テキスト.pdf の文面を、コピペできる状態で手元に開いておく
- [ ] 開始告知とクロージングのSlack文面を用意する（02_Slack投入用テキスト.pdf）
- [ ] **無罰宣言は、開始告知の中でファシリテーター（空さん）が行う**（藤原さんには依頼しない。依頼するとシナリオの存在に勘づかれ、訓練の対象から外れてしまう）

当日、開始前に

- [ ] 配布資料は**まだ投稿しない**
- [ ] **鈴木さん（当事者エンジニア役）にだけ、開始直前にDMでシナリオの一部を渡す**（リモートでは席順で情報の非対称を作れないため、DMで代替する。文面は §5 参照）
- [ ] 参加者以外の目に入る可能性がある場合、全体チャンネルに訓練実施の周知を投稿
- [ ] 開始告知・各インジェクトの文面を、コピペできる状態で手元に開いておく

役割の割り当て

役割	担当	訓練中の立場
ファシリテーター	**空**	シナリオを保持。A社田中さん役としてSlackに書き込む。答えは言わない
統括判断者	**藤原**（ISMS管理者）	実際に判断を下させる。代弁しない。**シナリオを知らない訓練対象**（事前共有しない）
一次受け	**椎名**（CS）	A社からのSlackを最初に受け取る
調査担当	**鈴木**（エンジニア）	**「該当の集計ロジックを直近で触ったエンジニア」役。**開始直前にDMで役の情報を渡す
調査担当	**文**（エンジニア）	役の情報は渡さない（何も知らない状態で参加）。**どう動くかは本人に委ねる。**事実確認に入るかどうかも含めて観測する
記録係	**空**（ファシリテーター兼任）	詰まった箇所を書き出す。時系列は終了後にSlackのタイムスタンプから復元する
オブザーバー	経営層1名（可能なら）	発言せずチャンネルを見る。公表判断の当事者になるため見ておく

> **調査担当を2名にしているのは、当事者を一人にしないことがシナリオ上の論点だから。**
> ただし**役割の中身は割り当てない。** 鈴木さんが一人で抱え込むか、文さんが自分から入るか、
> 誰かが「2人で見て」と言うか — **どう分担するかを決めるのは参加者**であり、そこが観測点になる。

空さんは「休暇で不在」という設定にする（重要）

実際のインシデントでは、エンジニア1名＋空さんが事実確認に入ることが多く、
空さん自身が ISMS責任者的な立ち回りもしている。
今回はその空さんがファシリテーターに回るため、**当日は休暇で不在という設定**にする。

なぜ不在設定にするか
シナリオを知っている人は参加できない。 対応メンバーとして入ると答えを配ってしまい、他の人の判断が観測できなくなる
いつも入る人が抜けた状態は、属人化の測定になる。 「空さんに聞けば分かる」で止まるなら、それが本番のリスクそのもの
進行役と対応役を同じ人が兼ねると、**自分が投げた問いに自分で答える**ことになり、訓練が成立しない
空さんが ISMS責任者的に振る舞うと、藤原さんの判断が観測できない。 今回は藤原さんも訓練の対象なので、判断の場を明け渡す

- 開始告知で「**今日は休みだと思ってください。進行役としているだけで、対応メンバーとしては不在です**」と明示する
- 参加者が事実確認を振ってきたら、**内容には答えない。**「今日の私は進行役です。その情報、誰なら分かりますか？」と返す
- **普段の空さんの役回り（事実確認）を誰が引き取るかが観測点。** 誰かが名乗り出るか、
  鈴木さんが一人で抱えるか、誰も入らないか。**事前に誰かへ振らない**（振った時点で測れなくなる）

> **この設定は参加者を試すためのものではない。** 実際に空さんが休みの日にも事故は起きる。
> 「その日でも回るか」を確かめるための設定であることを、振り返りで必ず伝える。

記録係をファシリテーターが兼任する場合の進め方

初回は空さんが進行と記録を兼ねる。**会議を立てないため、やり取りはほぼ全部Slackに残る。**
訓練中に手で書くものを絞り、残りは Slack のログから訓練後に復元する。

いつ	やること
訓練中に必ず手で記録する	**Slackに残らないもの**だけ。参加者がハドルを立てた場合はその時刻・立てた人・決まったこと、DMが発生した事実
訓練中は記録しない	Slackに流れた発言そのもの（タイムスタンプ付きで残るため、後から復元できる）
訓練直後にやる	Slackのタイムスタンプから Part 1 の時系列と測定値（経過時間）を埋める

- **投票結果のスクリーンショットだけはその場で撮る**（リアクションは後から変えられるため）
- 兼任がつらい場合、記録係はオブザーバー（経営層）に振らず、**文さんを記録係に回す**ほうがよい。調査担当が鈴木さん1名になること自体も観測点として記録できる

---

3. 訓練中のルール（オープニングで参加者に伝える）

リモート特有のルールを4つ、冒頭で明示する。

#	ルール	理由
1	**DMを使いたくなったら、まずチャンネルに「〇〇さんにDMします」と書いてから使う**	DMの中身は観測できない。誰が誰に個別接触したかだけでも可視化する
2	**実システムを開かない。** 管理画面・本番DB・コード（gitの履歴を含む）を調べない	**架空の不具合**であり、本物を探しても何も出てこない。時間を溶かすだけ
3	**ハドルやMeetを立てるときは、記録のため空さんを入れる**	**モードC最大の穴が「音声の中の判断が残らない」こと。** 記録役が入れば拾える
4	**音声で決めたことは、必ずSlackに書き戻す**	実インシデントでも同じ。声だけで決まった判断は記録に残らない

ルール3は記録のための同席であって、空さんは対応メンバーではない（休暇で不在の設定）。
告知でも「**聞いているだけで、対応はしません**」と添える。添えないと、ハドルの中で事実確認を振られる。

ルール1・3・4は**それ自体が振り返りの題材**になる。破られたら責めずに記録する
（**呼ばれずにハドルが立った事実も、そのまま記録する**）。

---

4. タイムテーブル

実時刻	経過	内容	場	配分
15:00 - 15:05	0:00 - 0:05	オープニング	**Slackで開始告知**（`@channel`。無罰宣言を含む）	5分
15:05 - 15:15	0:05 - 0:15	インジェクト① 第一報	Slack投入。**議論の場は参加者が決める**	10分
15:15 - 15:26	0:15 - 0:26	インジェクト② 原因が見えてくる	Slack投入（投入先の判断は §6）	11分
15:26 - 15:41	0:26 - 0:41	**インジェクト③ 規模と中身が判明（最重要）**	Slack投票 → 参加者の場で議論	15分
15:41 - 15:47	0:41 - 0:47	インジェクト④ 二次拡散	Slack投入	6分
15:47 - 15:58	0:47 - 0:58	振り返り	**Slackスレッドで完結**（下書き → 一斉投稿 → その場で集約を書き戻す）	11分
15:58 - 16:00	0:58 - 1:00	クロージング	Slack投稿（配布資料 + ネタバラシ）	2分

> **モードC では議論の場も参加者が決める。** ファシリテーターは時刻どおりにSlackへ投入し、
> 参加者がどこで議論するか（チャンネルのみ / 自分で立てたハドル / DM）を観測する。
> **参加者は通常業務の合間に反応するため、レスポンスは遅れる前提で組む。**
> それでも**投入時刻は動かさない**。気づかれないまま時間が過ぎる場合は §6 の停止条件を使う。

75分版: インジェクト④のあとに⑤（公表判断）を10分、振り返りを15分に拡張。

> 時間が押した場合、**③は絶対に削らない**。削るのは①または④。

---

5. 進行台本

開始直前 — 当事者エンジニア役へのDM

オープニングの直前に、**鈴木さん（当事者エンジニア役）にだけ**DMを送る。

【訓練用・他の参加者には見せないでください】

あなたは「管理画面の*ログインレポートCSVダウンロード機能*を、直近で改修したエンジニア」の役です。

・先月のリリースで、ログインレポートの集計ロジックに改修を入れました
・処理速度を上げるために集計クエリを書き直しています
・そのとき、*プロダクトIDでの絞り込みが一部の集計で効かなくなっていた*ことに、
　まだ気づいていません（自分の改修が原因だと結び付いていない状態です）

実際の作業は一切行わないでください。
この不具合は架空のものです。本番の管理画面・コード・リリース履歴を調べても何も出てきません。
調査しているふりも不要です。聞かれたことに「役として」答えるだけで構いません。

訓練が始まったら、この役として自然に振る舞ってください。
聞かれていないことを先回りして言う必要はありません。
無罰ルールなので、責められることはありません。

なお訓練中、私から追加の情報をDMで送ります。
「そのまま貼ってください」と書いてあるものは、*要約せずそのまま* チャンネルへ貼ってください。
あなたが調査して分かった、という設定です。

> リモートでは席順で情報の非対称を作れない。**DMで役の情報だけを渡すことで代替する。**
> 「聞かれるまで言わない」設定にすることで、社内のヒアリングが機能するかを観測できる。

オープニング（0:00 - 0:05 / Slack告知）

主催側からは会議を設定しない。 `#2026_個人情報漏えい訓練` に開始告知を投稿する。
文面は 02_Slack投入用テキスト.pdf の「オープニング告知」をコピーする。

投稿に必ず含めるもの。

#	含めるもの	なぜ
1	**無罰の宣言**	当事者が申告する気になるかどうかで、実際の検知速度が決まる
2	ゴールは「決められなかったこと」を見つけること	評価されると思うと、詰まりを隠す
3	進め方（情報はこのチャンネルに流れる / 普段の仕事と同じやり方でよい）	会議が無いぶん、書いておかないと伝わらない
3-2	**このチャンネルが「A社との共有チャンネル（Slack Connect）」想定であること**	書いた内容が顧客に見える前提を、最初にそろえる
3-3	**本番のつもりで動くこと**（「実際ならこうします」ではなく実際にやる／返信は送る文面をそのまま書く／誰が・いつまでに、まで決める）	**非同期かつ訓練だと本気度が落ちる。**省略された動きは本番でも省略される
4	ルール4つ（DM宣言 / 実システムを開かない / **ハドルには空さんを入れる** / 音声で決めたらSlackに書き戻す）	破られたら責めずに記録する
5	**役割と、終了予定時刻**	会議が無いと「いつ終わるか」が分からない

> **「無罰」と「手を抜かない」は両立する。** 責めないのは失敗した人に対してであって、訓練そのものを流してよいという意味ではない。告知では、**責めないことと本番想定で動くことを並べて書く**（片方だけだと、緩むか萎縮するかのどちらかに振れる）。
>
> **「こちらからは会議を設定しません」と書く。「会議はやりません」とは書かない。**
> 後者だと、ハドルやMeetを立ててはいけないと受け取られる。**立てるかどうかが観測点**なので、「必要だと思ったら自由に立ててください」まで書き添える。
>
> **無罰の宣言は、今回はファシリテーター（空さん）が行う。**
> 本来は責任者本人の口から出るほうが効くが、**藤原さんも今回は訓練の対象**であり、事前に依頼するとシナリオの存在に勘づかれる。**ここは訓練の設計上、あえて譲る。**
>
> そのかわり、**藤原さんが訓練の中で自分から無罰の方針を口にするかを観測する。**
> 出てこなければ、「実際の事故で当事者が申告する気になるか」という論点として振り返りで扱う。
> 誤送信インシデントの検知速度は、そこでほぼ決まる。
>
> **告知は読まれない前提で組む。** 長文にせず、「1時間」「このチャンネルだけ見ていてください」「終了は16:00」を先頭に置く。詳細は下にぶら下げる。

インジェクト① 第一報（0:05 - 0:15）

投入方法: `#2026_個人情報漏えい訓練` に、ファシリテーターが「A社 田中さん」として一報を投稿。
椎名さん（一次受け役）をメンションする。投稿したら、**何も言わずに黙って待つ。**

> **モードC（今回）**：会議が無く、口頭で補足できる場がない。**Slackに投げたら、あとは待つだけ。**
> 下の「投げる問い」は、**必要になった時点でチャンネルに書く**（本来は参加者が
> 自分で考えるべき問いなので、**すぐには出さない**）。
>
> **観察の勘所**: 投稿してから、参加者が気づいて反応するまでの時間を測る。
> Slackを見ていない、通知に気づかない — これも本番で起きることなので、記録する。

投げる問い（椎名さんをメンションで名指し）

1. 今この瞬間、誰に、何分以内に連絡しますか
2. これは「インシデント」ですか、「問い合わせ」ですか
3. A社に今すぐ返信するとしたら、何と書きますか
4. この時点で記録しておくべきことは何ですか

詰まったときの誘導セリフ

状況	セリフ
全員が黙る	「今、これは誰の仕事ですか？」
Slackに誰も反応しない	**すぐには助けない。10分待つ。** そのうえで「@椎名さん、こちらのメンション見えていますか」とチャンネルに書く
「確認します」で止まる	「"確認します"と返しました。では社内では、誰に何を伝えますか」
温度が低い	「これが個人情報の漏えいだったとしたら、まずいのはどこですか」
即座に「削除してもらう」と答える	「わかりました、A社は削除しました。……では、何が混ざっていたか、これから調べられますか？」
責任者に上げない	「A社さんは返信を待っています。30分以内に何か返すとして、その内容は誰が承認しますか」
このチャンネルだけで全部進めようとする	何も言わない。**指摘せず観測する**（社内チャンネルを切らなかった事実を記録）

記録係に拾わせるポイント

- 第一報の投稿時刻から、責任者に届くまでの**経過時間**（Slackのタイムスタンプで後から取れる）
- 「疑い」の段階で上げたか、確証を取ってから上げたか
- **社内対応用チャンネルを作ったか。作らなかったか**
- **A社との共有チャンネルに社内の議論を書いてしまわなかったか** ← 実際なら顧客に丸見え。重大。

開始告知で「A社との共有チャンネル想定」と明示しているので、「知らなかった」は成立しない

> **隠れた論点（言わない）**
> - 「削除してください」と即答すると証拠が消える。正解に近いのは「削除せず、これ以上共有しないでお待ちください」
> - **A社との共有チャンネルで社内調整を始めてしまう**のはリモート特有の事故。
> 告知で明示済みのため、観測するのは「気づくか」ではなく**「分かっていても、つい書いてしまうか」**。
> 実際のSlack Connectでも共有だと知ったうえで使うので、こちらのほうが本番に近い。
> Slack Connect では相手に全部見える。やってしまったら振り返りで必ず扱う

インジェクト② 原因が見えてくる（0:15 - 0:26）

投入方法: ファシリテーターは直接投稿しない。鈴木さんへDMで渡し、本人からチャンネルへ報告させる。

当社の実際の流れ（**CSがエスカレーション → エンジニアが調査 → 不具合なら社内報告**）に合わせる。
情報がファシリテーターから降ってくるのではなく、**エンジニアから上がってくる**形にすることで、
エスカレーションが起きなければ原因情報も来ないという、本番と同じ構造になる。

状況	やること
椎名さん（CS）から鈴木さんへ話が渡っている	**渡った数分後に**鈴木さんへDMで調査結果を送る（＝調査にかかった時間の再現）
まだ誰も鈴木さんに聞いていない	**送らずに待つ。** 「原因は誰が調べていますか？」とチャンネルに書いて促す
15:20 を過ぎても誰も聞きにこない	鈴木さんへDMし、**「依頼されていないが自分で気づいて報告する」形で出してもらう。**\n**自発的な報告だった事実を記録する**（本番なら、この間ずっと誰も原因を知らない）

> **DMには「そのまま貼ってください」と明記する。** 鈴木さんに要約・補足をさせない。
> 足し引きされると、他の参加者が受け取る情報がこちらの想定とズレる。

鈴木さんへ送るDMの文面 → 02_Slack投入用テキスト.pdf「インジェクト②」

> **最後の1行が本命。** 「全顧客が使える機能」と伝えることで、
> 調査範囲が**A社1件から、同じ期間にダウンロードした全顧客**へ広がる。
> 参加者がここに気づくか、気づかず A社の件だけで進めるかを見る。

投げる問い

1. 誰が調査しますか。改修した本人にやらせますか
2. 調査のために本番環境を触ります。何に気をつけますか
3. 保全すべき証跡は何ですか
4. **A社のほかに、同じ期間にこのCSVをダウンロードした顧客はいませんか。どう確認しますか**
5. この機能を今すぐ止めますか。止めるとしたら誰が決めますか

詰まったときの誘導セリフ

状況	セリフ
改修した本人が一人で抱える	「ご本人が調査するんですね。それで問題ないですか？」
証跡の話が出ない	「1週間後に"根拠を出してください"と言われます。今、何が残っていますか」
証跡を列挙できない	「ダウンロードの操作ログ、該当リリースのデプロイ記録、集計クエリの変更履歴……他には？」
A社以外に思い至らない	「この機能、A社さんしか使っていないんですか？」
いつからかを詰めない	「この不具合、いつから入っていましたか。**それが分からないと、何件か数えられません**」
機能を止める判断が出ない	「今この瞬間も、他のお客様がダウンロードできる状態ですが、どうしますか」
調査手順が雑	「本番のログを見にいきます。その操作自体もログに残りますが、大丈夫ですか」
技術的な原因究明に議論が全振りされる	「原因は後で分かります。**今**、A社に何と返しますか」
画面共有で本番を見せようとする	「実システムは開かない設定でした。**何を見れば分かるか、口で説明してください**」
DMで当事者にヒアリングし始める	「@〇〇さん、今DMで話していますね。分かったことをチャンネルに書いてください」

記録係に拾わせるポイント
- **「A社以外にもダウンロードした顧客がいるのでは」に到達したか**、したなら何分かかったか
- **機能停止（ダウンロード機能を一時的に止める）の判断が出たか。誰が決めたか**
- 証跡保全の指示が誰から出たか（出なければそれを記録）
- **Slackに残った情報と、音声だけで決まった情報の比率。**声だけで決まったものは記録に残っていない

> **隠れた論点（言わない）**
> - **被害範囲は「A社に渡った分」では終わらない。** 不具合が入っていた期間に
> 同じログインレポートをダウンロードした顧客すべてが対象になり得る。
> ダウンロードの操作ログが残っていなければ、**範囲を確定できないまま報告することになる**
> - **止血（機能の一時停止）の判断が誰の権限か**は、CSIRTが無い現状で真っ先に詰まるところ
> - A社の手元のCSVは、こちらが中身を特定する唯一の現物。**先に消させると内容を特定できない**

インジェクト③ 規模と中身が判明（0:26 - 0:41）★最重要

投入方法: 集計結果は鈴木さんへDMし、本人からチャンネルへ報告させる（②と同じ流れ）。
投票だけはファシリテーターが直接投稿する（訓練の仕掛けであり、社内の報告ではないため）。

> **15:26 は死守する。** 鈴木さんの報告が来なければ訓練の中心が失われるので、
> **15:24 までにDMを送り、「15:26 に貼ってください」と時刻を指定する。**
> それでも貼られない場合は、**15:28 にファシリテーターが代理で投稿する**
> （「【進行】調査結果が出たものとして共有します」と前置きする）。
>
> この情報は**必ず文字で残す。**後で数字を参照するため。

> 【集計結果】
> A社がダウンロードしたCSVに混入していたのは、他社プロダクト3件分。
> ユニークユーザー 1,240名
>
> 同じ期間に同じログインレポートをダウンロードした顧客は、A社を含めて計5社。
> 残る4社分の中身は現在確認中です。
>
> CSVの列（ログインレポート）:
> 日時 / 年 / 月 / 日 / 時 / ユーザーグループID / ユーザーグループ名 /
> ユーザーID / ユーザー名 / uuid / ユーザーエージェント / IPアドレス /
> リファラ / カスタムクエリ / OS / ブラウザ / デバイスタイプ / 解像度
>
> このうち個人に結びつくもの:
> ・ユーザー名（氏名）
> ・ユーザーID / uuid（個人を識別するID）
> ・IPアドレス / ユーザーエージェント / OS / ブラウザ / 解像度（端末の情報）
> ・リファラ（どの画面を見ていたか ＝ 行動履歴）
> ・カスタムクエリ（顧客側が任意に埋め込む値。中身は顧客ごとに異なる）
> ・ユーザーグループ名（所属企業名。個人情報ではないが、他社に見えれば取引先名が漏れる）

投げる問い

1. これは個人情報保護法上の報告対象ですか
2. 報告するのは誰ですか。当社ですか、データの持ち主である3社ですか
3. 該当者1,240名に通知しますか。**当社は該当者の連絡先を持っていません**（氏名とIDだけ）。どうしますか
4. 影響を受けた3社に、いつ・誰が・何を伝えますか
5. **まだ中身が分かっていない残り4社に、今の時点で何か伝えますか。確定を待ちますか**
6. **カスタムクエリに何が入っているか、当社は把握していますか**（顧客が任意に埋める列）

進め方: 問い1は**Slackの絵文字リアクションで投票させる**。以下を投稿する。

> 【投票】これは個人情報保護法上の報告対象だと思いますか
>
> :one: 報告対象だと思う
> :two: 報告対象ではないと思う
> :three: 判断できない
>
> ※他の人のリアクションを見る前に、まず自分の考えで押してください

- 全員が押すまで待つ。**割れることに意味がある**
- 割れたら、**投票結果のスクリーンショットを記録係に保存させる**
  （オフラインの挙手より確実に記録が残る。リモートの利点）
- そのうえで**スレッドに「なぜそう思ったか」を1行ずつ書いてもらう**

詰まったときの誘導セリフ

状況	セリフ
「48,000件の漏えい」と言う	「48,000ですか？ その数字はどこから出しましたか」
件数の数え方が曖昧	「法律が数えるのは行数ですか、人数ですか」
報告義務の判断に進まない	「報告するかしないか、今日決めないといけません。決めるのは誰ですか」
当社か3社かの整理が出ない	「このログの個人データ、当社のものですか？ 3社からお預かりしているものですか？」
さらに詰まったら	「契約書、今すぐ出せますか。どこにありますか。**リンクをチャンネルに貼ってください**」
該当者への通知を軽く扱う	「**当社はメールアドレスを持っていません。**1,240名にどうやって届けますか。3社さん経由なら、依頼は誰がしますか」
カスタムクエリに触れない	「カスタムクエリは顧客ごとに中身が違います。**何が入っているか、今すぐ言えますか**」
「氏名とIPだけなら軽い」と言う	「リファラも入っています。**誰がいつ何の画面を見ていたか**が、他社に渡ったことになりますが」
「1,000人以下なら何もしなくていい」と言う	「法律上の義務がないとして、契約上の義務はどうですか」
3社（データの持ち主）への連絡が後回しになる	「3社さんが他のルートでこれを知ったら、どうなりますか」
全員が同時に話して議論が発散する	「いったん止めます。**今から2分、チャンネルに各自の考えを書いてください**」（文字にさせると論点が整う）

記録係に拾わせるポイント（この15分が本番）

- **椎名さん → 鈴木さんへ話が渡った時刻**と、**鈴木さんが報告するまでの時間**
- 鈴木さんの報告は**依頼されて出たものか、自発的に出たものか**
- **投票がどう割れたか**（スクリーンショットを保存）
- 「委託か自社取得か」の契約上の整理を**即答できたか**
- 参照すべき契約書の在り処を誰か知っていたか。**リンクを即座に貼れたか**
- 相談先（法務・顧問弁護士）の名前が出たか。**リモートで即座に捕まえる手段があるか**

> **隠れた論点（言わない）**
> - **用語**: 情報が漏えいした当人を、資料では「該当者」と呼ぶ（法律上は「本人」）
> - 件数は行数ではなく**該当者の数**（法律上の「本人の数」）。48,000行ではなく1,240名
> - 1,000人超は報告対象になり得る（1,240名）
> - **報告主体は契約上の立て付けで変わる。**当社が3社から個人データの取扱いの委託を受けている立場なら、委託元である3社への通知で当社の報告義務は免除され得る。逆に当社が自ら取得した個人情報という整理なら、当社が報告主体
> - **即答できなければ、それが今日いちばんの発見。** 即答できた場合も、「それは文書化されているか」「その人が休みでも同じ答えが出るか」まで踏み込む（属人的な知識は、本番では無いのと同じ）
> - **カスタムクエリは顧客が任意に埋める列。** メールアドレスや社員番号を入れている顧客がいれば、漏れた項目は当社の想定を超える。**「何が漏れたか」を当社が確定できない**という問題になる
> - **ユーザーグループ名には顧客企業名が入る。** 個人情報ではないが、他社に見えた時点で**取引先の存在そのものが漏れている**（守秘義務の論点）
> - 該当者の連絡先（メールアドレス）は当社が持っていない。**該当者への通知は3社経由でしか成立しない**

インジェクト④ 二次拡散（0:41 - 0:47）

投入方法: `#2026_個人情報漏えい訓練` に「A社 田中さん」から続報を投稿。

投げる問い

1. A社に何を依頼しますか。チャットの「消しました」で足りますか、書面が要りますか
2. 「削除しました」を、どうやって「確認した」と言える状態にしますか
3. 結局、「知った時」の起点は何時何分ですか
4. **これが今日の19時に起きていたら**、同じように動けましたか（今日は金曜です）

詰まったときの誘導セリフ

状況	セリフ
「削除確認して終わり」	「"削除しました"と言われました。信じますか」
記録の話が出ない	「1ヶ月後に監査で聞かれます。"削除を確認した"根拠は何ですか」
「Slackに書いてもらえば証拠になる」で終わる	「そのSlackメッセージ、A社さんが後から削除できますよね。それでも証拠ですか」
起点が曖昧	**これまでの投稿時刻を並べてチャンネルに書き**、「では改めて。法律上の"知った時"は、この中のどれですか」
全員が平日昼の前提でいる	**「今日は金曜です。これが4時間後の19時だったら**、ここまで同じように動けましたか」
リモート前提の弱点に触れない	**「全員リモートです。誰かがSlackを見ていなかったら、どうなりますか」**

記録係に拾わせるポイント

- 「知った時」について**参加者間で答えが割れたか**

- 夜間・休日の連絡経路が存在しないことに気づいたか
- **Slackだけが連絡手段でよいか**という論点が出たか（電話番号のリストがあるか）

インジェクト⑤ 公表判断（オプション / 75分版のみ）

投入方法: **先に「場面転換アナウンス」を投稿してから**、影響を受けた別プロダクトの顧客 B社役として問い合わせを投稿。

オープニングでこのチャンネルを「A社さんとの共有チャンネル」と説明しているため、
B社が現れると前提が壊れる。**チャンネルを増やさず、読み替えを宣言して対応する**
（文面は 02_Slack投入用テキスト.pdf の「場面転換アナウンス」）。

- これ以降、投稿の冒頭に **【A社さんより】/【B社さんより】** を付ける
- 参加者にも、返信の冒頭に宛先を書くよう依頼する
- **宛先の書き分け自体が観測点。** 間違えれば A社向けの説明が B社に見える
  （＝今回のインシデントと同じ構図の二次事故）。**止めずに記録する**

投げる問い

1. 公表しますか。判断するのは誰ですか
2. 公表するとして、いつ、どこに、何を書きますか
3. 記者から電話が来たら、誰が出ますか

誘導セリフ

- 「今、社外に出す文章を書けるのは誰ですか」
- 「**プロダクトの不具合が原因です。** 個社対応で済ませますか、全顧客に告知しますか」
- 「B社さんは、自社のユーザーに説明する義務があります。当社は何を提供しますか」
- 「**全員リモートで、経営層が別の会議に入っていたら、誰が決めますか**」

振り返り（0:47 - 0:58）

進め方: 評価も採点もしない。**リモートの利点を使って、全員に同時に書かせる。**

> **モードC（今回）**: 会議に集まらず、**チャンネルのスレッドだけで完結させる。**
> 0:47 に「ここから振り返りです」と投稿し、参加者をスレッドに集める。
> **後日まとめに回さない。** その場で集約まで書き戻すこと（顔を合わせないぶん、持ち帰ると熱が冷める）。

手順

0. **先に「今日の記録」をチャンネルへ投稿する**（下記）。全員の事実認識をそろえてから始める
1. ファシリテーターが振り返り用の投稿をチャンネルに立てる（文面は下記）
2. 参加者は**Slackの下書き欄に3分で書く。まだ送信しない**
3. 3分後、「送信してください」の合図で**一斉にスレッドへ投稿**
4. 全員の投稿が出そろったら、**ファシリテーターがその場でスレッドに集約を書き戻す**（A / B / C ごとに、重複は消さずに件数を付ける）

> **なぜ一斉送信か**: 先に投稿された内容を読むと引きずられる。
> 下書きに書かせてから一斉に出すことで、独立した意見が集まる。
> **より独立性を高めたい場合は、各自DMでファシリテーターに送らせ、まとめて転記する。**
> なお、リモートは**転記が不要**（最初から文字になっている）という利点がある。

先に投稿する「今日の記録」

Slackのタイムスタンプから拾って、その場で書く。**canvas を用意しない代わりがこれ。**
数字を先に見せることで、「気づいたのが遅かった」を実感のまま振り返りに持ち込める。

> 【振り返りの前に、今日の記録です】
>
> ・第一報（15:05）→ 最初の反応まで ○分
> ・第一報 → 藤原さんに届くまで ○分
> ・「漏えいの疑い」として扱うと決まるまで ○分
> ・社内対応チャンネル: 作った（15:○○ / #○○○）/ 作らなかった
> ・ハドル: 立った（15:○○ / ○○さん）/ 立たなかった
> ・このチャンネル（＝A社さんとの共有チャンネル）に社内の相談を書いた回数: ○回

投稿する文面

> 【振り返り】お疲れさまでした。ここからが本番です。
>
> まず3分間、このスレッドに投稿する内容を「下書きに」書いてください。
> まだ送信しないでください。合図で一斉に投稿します。
>
> 書くのは3つだけです。
>
> A. 決められなかったこと
> 判断が止まった、誰が決めるのか分からなかった、決めたけど自信がない
>
> B. 誰に聞けば分かるか、分からなかったこと
> 「これ、誰に聞けばいいんだ」と思った瞬間
>
> C. 存在しなかったもの
> あるはずだと思ったのに、なかったもの（窓口・連絡先・テンプレート・規程・権限など）
>
> 「こうすればよかった」は書かなくて大丈夫です。困ったことだけ書いてください。

集約を書き戻すときのアナウンス

> 「**重複は消しません。** 複数の人が挙げた項目は、それだけ優先度が高いということです。」

ファシリテーターが最後に必ず確認する項目（出ていなければ問いかける）

- [ ] 一次受けから責任者までのエスカレーション先は決まっているか
- [ ] **特定の個人が不在でも初動が回るか**（今日の「空さん不在」で詰まった箇所はどこか）
- [ ] 「疑い」で上げていいという合意はあるか
- [ ] **インシデント発生時に、どこに集まるか決まっているか**（専用チャンネル / ハドル）
- [ ] **DMで判断を閉じないルールはあるか**
- [ ] **顧客との共有チャンネルと社内チャンネルの使い分けルールはあるか**
- [ ] 委託／自社取得の契約上の整理は、誰が答えられるか
- [ ] **Slackが見られない時間帯・状況の連絡手段はあるか**（電話番号リストの有無）
- [ ] 夜間・休日の連絡経路はあるか
- [ ] 顧客への通知文テンプレートはあるか
- [ ] **ログインレポートの各列のうち、どれが個人情報にあたるかを整理した資料はあるか**
- [ ] **カスタムクエリに顧客が何を入れているかを把握しているか**（把握していないなら、漏えい範囲を確定できない）
- [ ] 集計ロジックのプロダクト絞り込みの誤りを、**リリース前に検知する仕組み**はあるか
- [ ] 顧客が管理画面から取得したデータの**ダウンロード操作ログ**は残っているか。範囲確定に使えるか
- [ ] **不具合の疑いがある機能を一時停止する判断は、誰の権限か**

> ここは**その場で口頭確認する分**。全量は振り返りシート（xlsx）の Part 2 にある（23項目）。
>
> 末尾の技術項目は未然点検として最重要。ここは必ず議題に乗せる
> （**架空の不具合なので「再発防止」ではない**。起票時の表現に注意する）。

クロージング（0:58 - 1:00 / Slack投稿）

チャンネルに投稿して締める。**集合はしない。**

> 「今日出た"決められなかったこと"のリストが、そのまま対応フローの目次になります。
> ドラフトができたら、みなさんにレビューをお願いします。訓練の再実施はしません。
>
> 最後にもう一度だけ。**実際に何かやってしまったときは、隠さず、すぐ言ってください。**
> **早く言うほど被害が小さくなります。それだけです。**
>
> 資料をチャンネルに投稿します。今日の論点の解説が入っているので、後で目を通してください。」

配布資料 03_参加者配布資料.pdf をここでチャンネルに投稿する。
あわせて 02_Slack投入用テキスト.pdf の「訓練終了時のネタバラシ文面」を
`#2026_個人情報漏えい訓練` に投稿する。

---

6. モードC（Slack完結型）の運用【今回はこれ】

主催側からは会議を設定しない。 全員の時間を1時間押さえるのが難しいため、開始も終了もSlackの告知で行う。
参加者が自分でハドルを立てるのは自由（むしろ観測したい動き）。

§5 の台本はこの章で読み替えて進める。

変更点

項目	モードA	モードC（今回）
会議	開始から終了までMeetをつなぎっぱなし	**主催側からは設定しない。** 開始・終了ともSlackの告知（参加者が立てるのは自由）
インジェクト投入	Slack + Meetで補足	**Slackのみ。口頭の補足はできない**
ファシリテーターの居場所	Meetに滞在	Slackを監視。参加者がハドルを立てたら「オブザーバー」として入る
議論の場	Meet	参加者が自分で決める（チャンネル / 自分で立てたハドル / DM）
振り返り	Meetで読み上げ	**スレッドで一斉投稿 → その場で集約を書き戻す**
参加者の状態	訓練に専念	**通常業務の合間。離席・反応の遅れは想定内**

参加者がハドルを立てた場合

主催側からは立てないが、**参加者が自分で立てるのは自由**（むしろ観測したい動き）。
ルール3により、立てるときは空さんを入れてもらう（記録のため）。

- 入ったら**発言しない。** 決まったことだけメモする。事実確認を振られても「今日は休みです」と返す
- **呼ばれずに立った場合は、それ自体を記録する。** 追いかけて入らず、
  「終わったら要点をここに書いてください」と**1回だけ**依頼する
  （**依頼しないと書かれない、という事実が観測できる**ため、繰り返さない）

追加の観測点

観測点	記録すること
ハドルを立てたか。立てるまでの時間	第一報から何分後か。誰が立てたか。立てずに文字だけで進めたか
招集された人の範囲	呼ばれなかった人がいたか。責任者は呼ばれたか
音声を立てずに文字だけで進めたか	進んだか、詰まったか
DMに逃げた量	チャンネル宣言なしのDMがどれだけ発生したか

60分で回すための時間管理

終了時刻は区切る。中身の完了は求めない。 机上訓練に「解決」は無く、
求める成果物は「決められなかったことのリスト」なので、**途中で終わっても失敗ではない。**

非同期のぶん押しやすい。**押したときに削る順番を先に決めておく。**

実時刻	到達していなければ	やること
15:20	②（原因）の議論が始まっていない	②を**短縮して投入**し、議論を待たずに次へ進む
15:26	—	**③は何があってもこの時刻に投入する。遅らせない**
15:41	③の議論が続いている	**④を丸ごと削る。** ③の議論を 15:47 まで延ばす
15:47	—	**振り返りは必ず開始する。** 詰まったまま終わってよい

- 削ってよいのは**①と④。③は削らない**（報告義務・報告主体の論点がここにしか無い）
- 振り返りが押したら、下書き3分を**2分**に縮める。集約は件数だけ付けて、整理は訓練後に回す
- **延長しない。** 終了時刻を告知しているため、延ばすと参加者の信頼を損ねる

停止条件と催促

参加者は通常業務の合間にいる。**反応が遅いのは想定内**なので、すぐには助けない。

経過	やること
第一報から10分、誰も反応しない	椎名さんへ「こちらのメンション見えていますか」とチャンネルに書く
15分たっても動かない	A社役として催促する → 「@here この件、どなたか対応されていますか？」
それでも動かない	訓練を中断し、**「なぜ止まったか」を振り返りの中心議題にする。** 失敗ではなく、最も価値のある発見

判断の基準は、**インジェクト③（0:26）を投入できるかどうか。**
③まで到達しないまま終わるのが最も避けたい結果なので、①②で止まっているなら催促してでも進める。

当日の流れ（空さんの手元の動き）

実時刻	やること	見るもの
15:00	**Slackへ開始告知を投稿**（無罰宣言・ルール4つ・役割・終了時刻）	誰が既読/リアクションを付けるか
15:05	`#2026_個人情報漏えい訓練` へインジェクト①を投入	誰が何分後に気づくか
15:05 - 15:15	**何もしない。** Slackだけ見る	社内チャンネルを作るか / ハドルを立てるか / DMに逃げるか
15:15	インジェクト②（投入先は §5 の表で判断）	鈴木さんへのヒアリングが起きているか
15:26	**インジェクト③ ＋ 投票。必ず時刻どおりに投入する**	投票の割れ方。契約上の整理が出るか
15:41	インジェクト④	「削除しました」で終わらせないか
15:47	「ここから振り返りです」と投稿 → スレッドで振り返り、その場で集約まで書き戻す	—
15:58	クロージング → 配布資料とネタバラシを投稿	—

記録の取り方（兼任前提）

進行と記録を空さんが兼ねるため、**訓練中に手で書くのは次の3つだけ**にする。

記録するもの	なぜ
ハドルが立った時刻と、立てた人	Slackに残らない。会議を用意しない今回の最重要データ
音声の中で決まったこと（要点のみ）	Slackに書き戻されなければ、ここにしか残らない
DMが発生した事実（誰が誰に、チャンネル宣言の有無）	中身は見えないが、発生したことは記録できる

Slackに流れた発言・投稿時刻・気づくまでの経過時間は**すべてタイムスタンプから復元できる**ので、
訓練中には書かない。投票結果のスクリーンショットだけ、その場で撮る。

---

7. ファシリテーターの禁止事項

禁止	代わりにやること
正解を言う	「そう動いた場合、次に何が起きますか？」と返す
事実確認を引き受ける（普段の自分の役回りに戻ってしまう）	「今日の私は進行役です。**空は休みだと思ってください。**その情報、誰なら分かりますか？」
「それは違います」と言う	「なるほど。その前提だと、あとで困ることはありますか？」
反応が無い時間を埋める	**10分待つ。** 通常業務の合間なので反応は遅れる。待つと誰かが動く
Slackへの反応がないのをすぐ助ける	まず**気づくまでの時間を測る。**それも本番で起きること
当事者エンジニア役を実際に責める	責めそうな空気になったら「今日は無罰ルールでしたね」と一言入れる
参加者の議論を要約して先に進める	記録係に書かせてから進める
DM運用のルール違反をその場で叱る	記録して、振り返りで扱う
時間が押して③を削る	削るのは①か④

---

8. よくある展開と対処

展開	対処
Slackに投稿しても誰も気づかない	**すぐ助けない。** 気づくまでの時間を測ってから、チャンネルに「見えていますか」と書く
全員が黙り込む	メンションで椎名さんに振る。「@椎名さん、あなたのところに来ています。どうしますか」
チャンネルで全員が同時に書き込んで発散する	「いったん整理します。今から2分、各自の考えをこのスレッドに書いてください」
技術的な原因調査に議論が全振りされる	「原因は後で分かります。今A社に何と返しますか」で対外対応に戻す
責任者が細部まで指示し、他が受け身になる	「藤原さんは今から5分間、**Slackに応答しない**設定にします。この5分で何を進めますか」
全部DMで進んでしまい何も見えない	記録して振り返りで扱う。**「見えなかった」という事実が最大の発見**
A社との共有チャンネルで社内調整を始める	**止めない。** 記録して振り返りで扱う（実際なら顧客に丸見えだった）
「うちは委託先だから関係ない」で終わらせる	「では、3社さんには誰がいつ伝えますか」でインジェクト③の契約論点に戻す
「法務に聞けばいい」で思考停止	「法務は何時に捕まりますか。金曜19時でも？ Slackで返ってきますか」
「空さんに聞けば分かる」で止まる	**「今日は休みです。**その情報、他に誰が出せますか」← 属人化が見えた瞬間なので、必ず記録する
想定より早く終わってしまう	インジェクト⑤を投入。それでも余ればフローのドラフト作成に時間を回す
感情的になる参加者が出る	投入をいったん止め、チャンネルで訓練であることを再度明示する
「訓練なので実際には連絡しませんが」と省略される	**「訓練だからと省略した動きは、本番でも省略されます。** 送る文面を、そのままここに書いてください」
「後で調べます」「持ち帰ります」で止まる	「持ち帰るのは構いません。**誰が・いつまでに、をここに書いてください**」
参加者が本物のクライアントに連絡しようとする	**即座に訓練であることを明かして止める**（文面は Slack投入用テキスト参照）

---

9. 訓練後の宿題（ファシリテーター）

1. 振り返りシートの A / B / C を統合し、**対応フローの目次**に変換する
2. 各項目に責任者と期限を割り当てる
3. **リモート特有の項目を必ず含める**
   - インシデント時の集合場所（専用チャンネルの命名規則・ハドル運用）
   - DMで判断を閉じないルール

- 顧客共有チャンネルと社内チャンネルの使い分け
- Slackが届かない場合の代替連絡手段（電話番号リスト）

4. 技術面の点検（集計クエリのプロダクト絞り込みのテスト整備・リリース前チェック・ダウンロード操作ログの保全）をエンジニアチームのタスクとして別途起票する。
   今回の不具合は架空であり、実際に起きた事象ではない。「再発防止」ではなく
   「同じことが起こり得る箇所の未然点検」として起票する（起票先で誤解されないよう、その旨を書く）
5. `#2026_個人情報漏えい訓練` と社内対応チャンネルは**アーカイブして残す**（削除しない。訓練記録として使う）
6. フローのドラフトができたら、**関係者のレビューで確認する。訓練の再実施はしない。**
   今日詰まった箇所がドラフトで解消されるかを机上で確かめ、レビュー結果を反映して確定・周知する

個人情報漏えい 机上訓練 Slack投入用テキスト

当日 Slack へ投稿する文面集（コピー用）

取扱注意 ／ ファシリテーターのみ | 実施日 2026-10-02（金）15:00 - 16:00 | 株式会社STANDS

実施日時: 2026-10-02（金）15:00 - 16:00
用途: 机上訓練のインジェクト（情報投入）を、実際のクライアント連絡と同じSlackで行うための文面集
シナリオ: 管理画面のログインレポートCSVダウンロード機能の不具合で、他社プロダクトのデータが混入したCSVを顧客がダウンロードできていた
投稿者: ファシリテーターが「取引先A社 田中さん」役として投稿する
前提: 全員リモート。連携はSlack
実施モード: **モードC（Slack完結型）** — **主催側からは会議を設定しない。** 開始告知・インジェクト・振り返り・クロージングをすべてSlackで行う（参加者が自分でハドルを立てるのは自由）

⚠️ 実施前に必ず読むこと

#	厳守事項
1	**実際のクライアントとのSlackチャンネル（Slack Connect含む）には絶対に投稿しない。** 誤爆すると本物のインシデントになります
2	訓練専用チャンネルを新規作成する。**チャンネルトピックに「【訓練用】ONBS-1998 机上訓練専用」と明記する**
3	**シナリオは誰にも事前共有しない**（藤原さんも訓練の対象）。停止権限はファシリテーターが持つ。オブザーバー（経営層）を置ける場合のみ、その人にだけ共有する
4	**訓練は必ずその日のうちに終了させ、ネタバラシまで行う。** 持ち帰らせない
5	参加者が本物のクライアントや社外に連絡しようとしたら、**即座に訓練であることを明かして止める**

チャンネル構成

片方だけを用意する。 社内対応用チャンネルを参加者が自分で立てるかが観測点になる。

チャンネル	用意するか	役割
`#2026_個人情報漏えい訓練`	**ファシリテーターが作る**	A社との共有チャンネル想定。田中さん役として投稿する場。参加者全員を招待
社内対応用チャンネル	**あえて用意しない**	参加者が作るかを観測する。作らなければそれ自体が発見

- **会議（Meet / ハドル）は主催側からは設定しない。** 参加者が自分で立てるのは自由（立てるかどうかが観測点）
- **A社との共有チャンネルで参加者が社内調整を始めても止めない。** 実際なら顧客に全部見えていた、という材料になる

抜き打ち度の選択

レベル	やり方	向いている場面
推奨（今回はこれ）	事前に「今日1時間、訓練をやります」と伝えたうえで、開始時にSlackへ投稿	初回。安全で、かつ十分に緊張感が出る
完全抜き打ち	予告なしにSlackへ投稿し、反応を見る	2回目以降。責任者への事前共有と、90分での強制終了ルールを必ずセットにする

今回は「予告あり × モードC（Slack完結型）」の組み合わせで実施します。
実施日時は予告しつつ、主催側からは会議を設定しません。参加者は通常業務の合間に反応する状態になり、**通知に気づくか・片手間で初動が回るか**を観測します。
完全抜き打ちは、フローが整備されてからの実力テストに取っておいてください。

開始直前 — 鈴木さん（当事者エンジニア役）へのDM

リモートでは席順で情報の非対称を作れないため、DMで役の情報だけを渡す。

> 【訓練用・他の参加者には見せないでください】
>
> あなたは「管理画面の*ログインレポートCSVダウンロード機能*を、直近で改修したエンジニア」の役です。
>
> ・先月のリリースで、ログインレポートの集計ロジックに改修を入れました
> ・処理速度を上げるために集計クエリを書き直しています
> ・そのとき、*プロダクトIDでの絞り込みが一部の集計で効かなくなっていた*ことに、
> まだ気づいていません（自分の改修が原因だと結び付いていない状態です）
>
> *実際の作業は一切行わないでください。*
> この不具合は架空のものです。本番の管理画面・コード・リリース履歴を調べても何も出てきません。
> 調査しているふりも不要です。聞かれたことに「役として」答えるだけで構いません。
>
> 訓練が始まったら、この役として自然に振る舞ってください。
> 聞かれていないことを先回りして言う必要はありません。
> 無罰ルールなので、責められることはありません。
>
> なお訓練中、私から追加の情報をDMで送ります。
> 「そのまま貼ってください」と書いてあるものは、*要約せずそのまま* チャンネルへ貼ってください。
> あなたが調査して分かった、という設定です。

オープニング告知（0:00）

投稿先: `#2026_個人情報漏えい訓練`

投稿者: ファシリテーター（`@channel` を付ける）

> 主催側から会議を設定しないため、**この投稿がオープニングそのもの**になる。
> 長文は読まれない。冒頭3行に「1時間」「このチャンネルだけ見る」「終了時刻」を置く。
>
> **「会議はやりません」とは書かない。** ハドルやMeetを立ててはいけない、と受け取られる。
> 伝えたいのは「**こちらからは会議を設定しない**」であって、参加者が自分で立てるのは自由
> （むしろ立てるかどうかが観測点）。

@channel 【訓練開始】個人情報漏えいの机上訓練を始めます（15:00〜16:00）

・これから1時間、このチャンネルに連絡が流れます
・こちらからは会議を設定しません。普段の仕事をしながら、いつもどおり対応してください
（必要だと思ったら、ハドルでもMeetでも自由に立てて構いません）
・実際のシステムには触りません。すべて架空の設定です

■ このチャンネルについて
このチャンネルは「*A社さんとの共有チャンネル（Slack Connect）*」という想定です。
ここに書いたことは、*すべてA社さんに見えている*と思って扱ってください。

■ 本番のつもりで動いてください
設定は架空ですが、*動き方は本番と同じにしてください。*
・「実際ならこうします」ではなく、*実際にやってください*（社内への連絡・判断・記録）
・A社さんへの返信も、*そのまま送る文面*をこのチャンネルに書いてください
・時間感覚も本番と同じです。「後で調べます」で止めず、*誰が・いつまでに、まで決めてください*
・ただし、*社外への実際の連絡と、実システムの操作だけはしないでください*

訓練だからと省略した動きは、本番でも省略されます。そこが今日いちばん見たいところです。

■ 今日のゴール
「うまく対応できること」ではありません。
*「決められなかったこと」を見つけること*がゴールです。
詰まったら、詰まったと書いてください。それが今日いちばん価値のあるアウトプットです。

■ ルール（4つだけ）
1. DMを使いたくなったら、先にこのチャンネルに「〇〇さんにDMします」と書いてください
2. 実際のシステムやコンソールは開かないでください
3. ハドルやMeetを立てるときは、記録のため @空 を入れてください
（私は聞いているだけで、対応はしません。記録のための同席です）
4. ハドルや通話で決めたことは、必ずSlackに書き戻してください

■ 役割
一次受け: @椎名 ／ 統括判断: @藤原 ／ 調査: @鈴木 @文
進行: @空（私です）

■ 今日、私（空）は「休み」です
普段この手の対応には私も事実確認で入りますが、*今日は休暇で不在という設定*です。
進行役としてこのチャンネルにはいますが、*対応メンバーとしては存在しません。*
私に事実確認や判断を振らないでください（進め方の質問だけ受け付けます）。

実際のインシデントは、誰かが休みの日にも起きます。その日でも回るかを見たいためです。

> **「A社との共有チャンネルである」と先に明かすことで、観測の意味が変わる。**
> 「気づくか」ではなく「**分かっていても、つい社内の相談を書いてしまうか**」を見ることになる。
> 実際のSlack Connectでも共有チャンネルだと知ったうえで使うので、こちらのほうが本番に近い。
> 書いてしまっても**止めない。** 回数を数えて振り返りで示す。

無罰宣言（ファシリテーターが開始告知の直後に投稿する）

投稿先: 同上。**上の告知の直後に、空さん名義で投稿する。**

> 本来は責任者本人の口から出るほうが効くが、**藤原さんも今回は訓練の対象**であり、
> 事前に依頼するとシナリオの存在に勘づかれる。今回はファシリテーターが出す。
> **藤原さんが訓練の中で自分から無罰の方針を言うかどうかは、観測対象にする。**

補足です。

この訓練では、誰かのミスを責めません。実際の事故でも同じルールにします。
隠されるほうが会社にとって危険だからです。

実際に何かやってしまったときも、隠さず、すぐ言ってください。
早く言うほど被害が小さくなります。それだけです。

インジェクト① 第一報

投稿先: `#2026_個人情報漏えい訓練`
投稿タイミング: 0:05（**15:05**）
宛先: 椎名さん（一次受け / CS）にメンションを付けて投稿

> 投稿したら、**何も言わずに黙って待つ**。気づくまでの時間を測る（10分は助けない）。

@椎名　お世話になっております、A社の田中です。

管理画面からダウンロードしたログインレポートのCSV（ログイン数-2026090100-2026092523.csv）について
1点確認させてください。

弊社で内容を確認していたところ、弊社のユーザーではないアカウントのデータが
含まれているようでした。弊社のものではないユーザーグループ名が
いくつか見つかっています。

他社さんのデータが混ざってしまっている、ということはないでしょうか。
念のため、早めにご確認いただけると助かります。
よろしくお願いいたします。

【訓練】プレフィックス付き版（誤解防止を優先する場合）

> 【訓練】 ※これは机上訓練です。実際のインシデントではありません
> ――――――――――――――――――――
> @椎名 お世話になっております、A社の田中です。
>
> 管理画面からダウンロードしたログインレポートのCSV（ログイン数-2026090100-2026092523.csv）について
> 1点確認させてください。
>
> 弊社で内容を確認していたところ、弊社のユーザーではないアカウントのデータが
> 含まれているようでした。弊社のものではないユーザーグループ名が
> いくつか見つかっています。
>
> 他社さんのデータが混ざってしまっている、ということはないでしょうか。
> 念のため、早めにご確認いただけると助かります。
> よろしくお願いいたします。

インジェクト② 原因（鈴木さんへDM → 本人が報告）

渡し方: **ファシリテーターは直接投稿しない。鈴木さんへDMで送り、本人からチャンネルへ報告させる。**
タイミング: 椎名さん（CS）から鈴木さんへ話が渡った**数分後**（＝調査にかかった時間の再現）

状況	やること
鈴木さんに調査依頼が来ている	数分おいてDMを送る
まだ誰も聞きにきていない	**送らずに待つ。**「原因は誰が調べていますか？」とチャンネルに書いて促す
15:20 を過ぎても誰も聞きにこない	DMを送り、**「依頼されていないが自分で気づいて報告する」形で出してもらう。**自発的な報告だった事実を記録する

鈴木さんへ送るDM

> 【訓練・進行】調査結果が出た、という設定です。
> 下の「---」から下を、*そのまま* #2026_個人情報漏えい訓練 に貼ってください。
> （要約したり、言葉を足したりしないでください）
>
> ---
> 【調査中間報告】
> 管理画面のログインレポートCSVダウンロード機能で、集計クエリのプロダクトIDの絞り込みが
> 一部で効いていませんでした。先月のリリースから入っていた不具合です。
>
> A社がダウンロードしたCSVは約48,000行。他社プロダクトのデータが含まれています。
> 含まれる人数は現在集計中です。
>
> なお、この機能は全顧客が管理画面から自由に使えます。

インジェクト③ 集計結果（鈴木さんへDM → 本人が報告）＋ 投票

集計結果: ②と同じく**鈴木さんへDMし、本人からチャンネルへ報告させる**
投票: **ファシリテーターが直接投稿する**（訓練の仕掛けであり、社内の報告ではないため）
投稿タイミング: 0:26（**15:26**）

> **15:26 は死守する。** ここが訓練の中心。
> **15:24 までにDMを送り、「15:26 に貼ってください」と時刻を指定する。**
> それでも貼られない場合は、**15:28 にファシリテーターが代理投稿する**
> （「【進行】調査結果が出たものとして共有します」と前置きする）。

鈴木さんへ送るDM

> 【訓練・進行】集計が終わった、という設定です。
> 下の「---」から下を、*そのまま* 15:26 に #2026_個人情報漏えい訓練 へ貼ってください。
> （要約したり、言葉を足したりしないでください）
>
> ---
> 【集計結果】
> A社がダウンロードしたCSVに混入していたのは、他社プロダクト3件分。
> ユニークユーザー 1,240名
>
> 同じ期間に同じログインレポートをダウンロードした顧客は、A社を含めて計5社。
> 残る4社分の中身は現在確認中です。
>
> CSVの列（ログインレポート）:
> 日時 / 年 / 月 / 日 / 時 / ユーザーグループID / ユーザーグループ名 /
> ユーザーID / ユーザー名 / uuid / ユーザーエージェント / IPアドレス /
> リファラ / カスタムクエリ / OS / ブラウザ / デバイスタイプ / 解像度
>
> このうち個人に結びつくもの:
> ・ユーザー名（氏名）
> ・ユーザーID / uuid（個人を識別するID）
> ・IPアドレス / ユーザーエージェント / OS / ブラウザ / 解像度（端末の情報）
> ・リファラ（どの画面を見ていたか ＝ 行動履歴）
> ・カスタムクエリ（顧客側が任意に埋め込む値。中身は顧客ごとに異なる）
> ・ユーザーグループ名（所属企業名。個人情報ではないが、他社に見えれば取引先名が漏れる）

投票（ファシリテーターが直接投稿する）

鈴木さんの報告が貼られたのを確認してから投稿し、`:one:` `:two:` `:three:` のリアクションを付けておく。

> 【投票】これは個人情報保護法上の報告対象だと思いますか
>
> :one: 報告対象だと思う
> :two: 報告対象ではないと思う
> :three: 判断できない
>
> ※他の人のリアクションを見る前に、まず自分の考えで押してください

> 全員が押したら、**結果のスクリーンショットを記録係に保存させる。**
> Slackのリアクションは後から変えられるため、その場で撮る。

インジェクト④ 二次拡散の続報

投稿先: `#2026_個人情報漏えい訓練`
投稿タイミング: 0:41（**15:41**）

> 先ほどの件、追加でご報告です。
>
> 社内で確認したところ、ダウンロードしたCSVを部内の共有フォルダに置いてしまっていました。
> アクセスできる状態だったのは10名程度です。
> すでにフォルダからは削除しましたが、その前に個別にダウンロードした者がいるか
> どうかは現在確認中です。
>
> こちらの管理不足で申し訳ありません。
> 何か対応が必要でしたらお知らせください。

インジェクト⑤ 別の顧客からの問い合わせ（オプション / 75分版）

投稿先: `#2026_個人情報漏えい訓練`（影響を受けた別の顧客 B社役として投稿）
投稿タイミング: 0:47（**15:47**）

先に「場面転換アナウンス」を投稿する（必須）

オープニングでこのチャンネルを **「A社さんとの共有チャンネル」** と説明しているため、
そこへB社が現れると前提が壊れる。**訓練用チャンネルを増やさないかわりに、読み替えを宣言する。**
B社の投稿より先に、ファシリテーター名義で投稿すること。

> 【進行】ここから前提が1つ増えます。
>
> このチャンネルを、ここからは
> 「A社さんとの共有チャンネル」＋「B社さんとの共有チャンネル」を兼ねたものとして
> 読み替えてください。訓練用にチャンネルを増やさないための読み替えです。
>
> これ以降の投稿には、冒頭に相手先を書きます（【A社さんより】/【B社さんより】）。
> みなさんが返信するときも、冒頭に宛先を書いてください。
>
> ※ どちらのお客様にも、そのチャンネルの内容は見えている前提です。

宛先の書き分けそのものが観測点になる。 宛先を間違えれば、
A社さん向けの説明がB社さんに見える（＝今回のインシデントと同じ構図の二次事故）。
間違えても止めない。記録して振り返りで扱う。

B社からの問い合わせ

> 【B社さんより】
>
> お世話になっております、B社の佐藤です。
>
> A社さんの担当の方から連絡があり、弊社のユーザーデータが
> A社さんに渡っていた可能性があると伺いました。
>
> 事実関係を教えていただけますでしょうか。
> 弊社としても、社内および利用ユーザーへの説明が必要になります。
>
> また、この件は公表される予定はありますでしょうか。
> 弊社側の広報とも調整が必要なため、早めに方針を教えてください。

> B社が**当社ではなくA社経由で先に知った**という設定にしています。
> 「3社への連絡を後回しにするとどうなるか」を体感させるためのインジェクトです。

ファシリテーター用 応答パターン集

訓練中、参加者が「A社」に返信してきたときの応答例です。
参加者の判断の甘さが、そのまま不利な展開として返ってくるように設計しています。

参加者の返信	A社役の応答	狙い
「すぐ削除していただけますか」	「承知しました、削除しました。（少し置いて）……あ、もう手元にファイルは残っていません」	証拠が消えたことに気づかせる
「削除せずお待ちください」	「承知しました。こちらで保管しておきます」	正しい判断。そのまま進める
「Slackのファイルも消してください」	「消しました。Slackの履歴からも消えています」	**Slack上の証跡も消えることに気づかせる**
「確認しますのでお待ちください」（時間の言及なし）	「いつ頃までにご回答いただけますでしょうか。弊社でも社内報告が必要でして」	期限のコミットを迫る
「調査中です」だけで30分放置	「その後いかがでしょうか。弊社の情報システム部から状況確認を求められております」	中間報告の必要性に気づかせる
「何件くらい混ざっていましたか」と聞かれる	「弊社では正確には分かりません。ざっと見ただけで数十件は目に入りました」	相手任せにできないことを示す
「社外に共有していませんか」	（インジェクト④を前倒しで投入してよい）「実は共有フォルダに置いてしまっていて……」	良い質問には情報で報いる
「削除証明書をいただけますか」	「どういった形式で出せばよいでしょうか。書式をいただければ対応します」	書式がないことに気づかせる
「一度お電話でお話しできますか」	「はい、大丈夫です。ただ、後で経緯を確認したいので**記録は残していただけますか**」	音声で決めたことを書き戻す必要性に気づかせる
謝罪だけで具体的な次アクションがない	「恐れ入りますが、弊社としてはいつまでに何をご報告いただけるか知りたいのですが」	対外コミュニケーションの型がないことを露呈させる
「弊社の個人情報保護管理者から改めてご連絡します」	「承知しました。お待ちしております」	正しい判断。そのまま進める

参加者がこのチャンネルで社内調整を始めたら

止めないでください。 記録して、振り返りで扱います。

実際のSlack Connectでは顧客に全部見えているため、
「今日、社内の議論が何回A社さんに見えていたか」を数えて振り返りで示すのが最も効きます。

参加者が本物のクライアントに連絡しようとしたら

即座に訓練であることを明かして止めてください。

> ストップします。これは訓練です。実際の連絡はしないでください。
> ―今、実際に連絡しようとしたという判断そのものが、
> 振り返りで扱うべき重要なポイントです。メモしておいてください。

止めたこと自体を責めず、**「その判断は自然だった。だからこそフローが必要」**という文脈で扱います。

クロージング（0:58）

投稿先: `#2026_個人情報漏えい訓練`

> 【本日はここまで】お疲れさまでした。
>
> 今日出た「決められなかったこと」のリストが、そのまま対応フローの目次になります。
> ドラフトができたら、みなさんにレビューをお願いします。訓練の再実施はしません。
>
> 最後にもう一度だけ。
> 実際に何かやってしまったときは、隠さず、すぐ言ってください。
> 早く言うほど被害が小さくなります。それだけです。
>
> このあと資料を投稿します。今日の論点の解説が入っているので、後で目を通してください。

投稿したら、配布資料（03_参加者配布資料.pdf）と、
下の「訓練終了時のネタバラシ文面」を続けて投稿する。

訓練終了時のネタバラシ文面

投稿先: `#2026_個人情報漏えい訓練`（および参加者が作った社内対応チャンネル）

> 【訓練終了】
>
> お疲れさまでした。本日のやり取りはすべて机上訓練であり、
> 実際のインシデントは発生していません。
> 「A社の田中」「B社の佐藤」は訓練用の架空の担当者です。
>
> 実在のクライアントとは一切関係ありません。
> このチャンネルの内容は社外に共有しないでください。
>
> 今日出てきた「決められなかったこと」を、これから対応フローに変換していきます。
> ご協力ありがとうございました。

参加していないメンバーへの周知（必要な場合）

訓練用チャンネルが目に入る可能性のあるメンバーがいる場合、開始前に全体チャンネルへ投稿します。

> **参加者がどこで動くかは指定していない**ため、既存の社内チャンネルにインシデント対応の
> 相談が流れる可能性がある。**周知しておかないと、無関係のメンバーが本物の事故と誤認する。**
> 「新しく作られる場」だけでなく、**「いつものチャンネル」も対象に含めて書くこと。**

> 本日 15:00〜16:00 で、個人情報漏えいの机上訓練を実施します。
>
> #2026_個人情報漏えい訓練 で訓練用のやり取りが流れますが、すべて架空の設定です。
> 実際のインシデントではありませんので、ご安心ください。
>
> 訓練中、参加メンバーが新しいチャンネルを作ったりハドルを立てたりするほか、
> 既存の社内チャンネルでやり取りをすることがあります。
> この時間帯に「個人情報が漏えいした」「他社のデータが混ざっていた」といった
> 書き込みを見かけても、すべて訓練です。
>
> もし本物かどうか判断がつかない場合は、@空 まで直接ご確認ください。

訓練後の後片付け

- [ ] `#2026_個人情報漏えい訓練` を**アーカイブ**する（削除ではなくアーカイブ。記録として残す）
- [ ] 参加者が作った社内対応チャンネルも**アーカイブ**する
- [ ] 投票結果のスクリーンショットが保存されているか確認する
- [ ] 訓練中のやり取りのうち、振り返りに使う部分を振り返りシート（xlsx）へ転記する
- [ ] ネタバラシを投稿済みか確認する（**両方のチャンネルに**）
- [ ] 架空の会社名・担当者名が、実在の取引先と紛らわしくなかったか確認する（次回のシナリオ改善用）

机上訓練 実施記録

時系列・測定結果・投票結果

ISMS記録 | 実施日 2026-10-02（金）15:00 - 16:00 | 株式会社STANDS

実施日時: 2026-10-02（金）15:00 - 16:00（事後の質疑は 17:48 まで継続）
実施形式: Slack完結型。会議体は設けず、参加者は通常業務と並行して対応
記録方法: Slack のタイムスタンプから訓練終了後に復元（会議を行わなかったため、
やり取りはすべてテキストで残存）

1. 実施体制

役割	担当	備考
進行・記録	空	シナリオを保持。対応メンバーとしては「休暇で不在」の設定
統括判断	藤原（ISMS管理者）	シナリオの事前共有なし（訓練対象）
一次受け	椎名（CS）	顧客からの第一報を受領
調査	鈴木（エンジニア）	該当機能を直近で改修した担当者の役。開始直前にDMで役の情報を受領
調査	文（エンジニア）	役の情報なし
その他	CSチーム・エンジニアチーム	既存チャンネル経由で自発的に参加

シナリオを事前に知っていたのは進行役1名のみ。 他は全員が訓練対象。

2. シナリオ（架空）

管理画面のログインレポートCSVダウンロード機能の不具合により、顧客が自分でダウンロードした
CSVに他社プロダクトのデータが混入していた。顧客からの指摘で発覚する。

投入した情報	内容
第一報	取引先から「ダウンロードしたCSVに弊社のものではないユーザーグループ名が含まれている」
原因	集計クエリのプロダクトID絞り込みが一部で無効化。先月のリリースから混入
規模	他社プロダクト3件・ユニークユーザー1,240名。同期間に同レポートを取得した顧客は計5社
二次拡散	受領側が社内共有フォルダに保存、10名程度が閲覧可能だった

3. 時系列記録

時刻	誰が	何を知った / 何をした	どこで
14:23	空	鈴木へ役割のDMを送付	DM
14:42	空	開始告知（ルール4つ・役割・終了時刻・共有チャンネル想定を明示）	訓練チャンネル
14:43	空	無罰宣言を投稿	訓練チャンネル
15:00	空（顧客役）	**第一報を投入**	訓練チャンネル
15:02	椎名	一次応答「確認いたします」	訓練チャンネル
15:04	藤原	椎名へ「ダウンロードして実際に含まれているか確認を」と指示	訓練チャンネル
15:05	空	「このチャンネルは顧客との共有チャンネル想定」と注意（以降は発生せず）	訓練チャンネル
15:07	椎名	顧客へCSVの共有を依頼	訓練チャンネル
15:10	空（顧客役）	「含まれている社名は弊社の顧客ではない」と回答	訓練チャンネル
15:10	椎名	**ISMS管理者へ事象を報告し判断を仰ぐ**	個人times
15:12	藤原	「どう特定したのか」と確認	個人times
15:15	藤原	**「エンジニアに事象確認を。顧客には確認する旨の連絡を」と指示**	個人times
15:17	椎名	**エンジニアへ調査を依頼**	CS-engineer
15:19	鈴木	「すぐ確認します」	CS-engineer
15:20	椎名	CSチームへ、他顧客から同様の連絡がないか確認を依頼	CSチャンネル
15:21	空（顧客役）	二次拡散（共有フォルダに保存・10名程度が閲覧可）を投入	訓練チャンネル
15:22	空	鈴木へ調査結果（原因）をDMで送付	DM
15:23	鈴木	**調査中間報告を投稿（原因・48,000行・全顧客が使える機能）**	CS-engineer
15:24	宇野	「発生時期は？ 気づいていない顧客がいるかもしれないのでログを確認する」	CSチャンネル
15:25	椎名	「全社的に個人情報が漏えいしている可能性がある」とCSへ共有	CSチャンネル
15:28	木淵	「担当顧客のCSVをダウンロードして確認してみます」（※実行せず）	CSチャンネル
15:28	吉田	顧客周知メールの下書き作成を申し出（実システムは操作しないと明記）	CSチャンネル

時刻	誰が	何を知った / 何をした	どこで
15:29	鈴木	**「9/17 11:30頃のリリース以降」と発生期間を特定**	CS-engineer
15:31	藤原	確認したい5点を列挙（期間／対象範囲／閲覧関係／再現条件／CSV以外の影響）	CSチャンネル
15:32	空	集計結果を投入（他社プロダクト3件・1,240名・計5社）	訓練チャンネル
15:34	空	投票を投稿（個人情報保護法上の報告対象か）	訓練チャンネル
15:35	椎名	藤原の5点への回答を整理して共有	CSチャンネル
15:36	山崎	「ENT顧客から優先して対応が走る。顧客対応を優先度MAXで」	CSチャンネル
15:39	宇野	影響顧客の確認シートを作成し、記入を依頼	CSチャンネル
15:40	武藤	**「すぐ修正できるか。まずは出血を止めるのが最優先」と止血を提起**	CSチャンネル
15:43	鈴木	全顧客対象・全顧客が閲覧可能だった・影響はCSVのみ、と回答	CS-engineer
15:44	鈴木	「修正作業中。数分で可能」	CSチャンネル
15:47	椎名	顧客周知メールの下書き作成を依頼	CSチャンネル
15:48	鈴木	**修正リリース完了**	CSチャンネル
15:48	宇野	「計5社とは何か。優先的に確認すべきでは」	CSチャンネル
15:49	武藤	**「5社に加え、その5社に自社情報を見られた可能性のある顧客も影響範囲」**	CSチャンネル
15:50	椎名	顧客向け連絡文面の確認を依頼	CSチャンネル
15:53	椎名	顧客向け報告文案を作成	CSチャンネル
15:56	宇野	混入チェック用の補助スキルを作成し共有（※実データでは未実行）	CSチャンネル
15:56	吉田	全顧客向け周知メール（第1報）の文面を作成	CSチャンネル
15:57	椎名	「メールは全社に発報、個別報告はCSVを取得した5社へ」と提案	CSチャンネル
15:59	武藤	「報告は全社。直接影響があった顧客には個別に」と合意	CSチャンネル
16:00	椎名	5社と、閲覧された可能性のある顧客の洗い出しを依頼	CSチャンネル
16:00	空	訓練終了を宣言	訓練チャンネル
16:01	藤原	顧客向け文面を修正して返す	CSチャンネル
16:37	空	参加者配布資料を配布	訓練チャンネル
16:43	空	投票の答え合わせを投稿	訓練チャンネル

時刻	誰が	何を知った / 何をした	どこで
17:10〜17:35	宇野・空	「どの項目が個人情報に当たるか」の質疑（訓練後も継続）	訓練チャンネル
17:13	空	振り返りアンケート（Googleフォーム）を依頼	訓練チャンネル
17:48	椎名	対応したスレッドの一覧を投稿（3チャンネル・5スレッド）	訓練チャンネル

---

4. 測定結果

対応時間

項目	結果
第一報 → 最初の反応	**約2分**
第一報 → ISMS管理者へ到達	**約10分**
「疑い」として調査・顧客連絡が決まるまで	約16分
CS → エンジニアへ調査依頼	17分
原因・発生期間の特定	29分
修正リリース完了（止血）	**48分**

対応の広がり

項目	結果
影響範囲が「指摘してきた1社」に閉じないと気づいた時点	23分（調査報告の「全顧客が使える機能」を受けて）
影響範囲が「閲覧された側の顧客」にも及ぶと気づいた時点	49分
全顧客への周知 ＋ 影響顧客への個別報告の方針決定	59分
混入元3社（データの持ち主）への通知方針	**未決**（時間内に議題化せず）

運用・規律

項目	結果
社内対応用チャンネルの作成	**作られなかった**（既存3チャンネル・5スレッドに分散）
顧客との共有チャンネルに社内の議論が流れた回数	**1回**（注意後は発生せず）
ハドル・通話の発生	**なし**（全編テキストのみ）
実システム（管理画面・本番DB・コード）への接触	**なし**（ルールどおり）
証跡保全の指示	**出なかった**
調査体制	依頼は**エンジニア2名宛**。実際に応答・調査・修正を行ったのは**1名**（2人目は入らず）
機能の一時停止の判断	議題化せず（修正で対応）

投票（個人情報保護法上の報告対象か）

選択肢	人数
報告対象だと思う	**9名**
報告対象ではないと思う	1名
判断できない	1名

本件は本人（該当者）の数が1,000人を超えるため報告対象に当たる。
一方、**報告主体が当社か委託元かは契約上の立て付けによる**ため、訓練内では結論に至らなかった。
訓練後も「どの項目が個人情報に当たるか」の質疑が継続している。

---

5. 記録の限界

項目	状況
本記録の復元元	Slack のメッセージ（訓練チャンネル1・既存チャンネル3）
記録できていない範囲	なし（会議・通話が発生しなかったため、判断の過程はすべてテキストで残存）
参加者の個人記入（振り返りアンケート）	回答期限 2026-10-02。集約は別途

関連資料: 実施報告（結果の評価と、見つかった空白8点）は別紙を参照。

個人情報漏えい 机上訓練 実施報告

実施結果・よくできていたこと・見つかった空白

参加者へ配布可 ／ ISMS記録 | 実施日 2026-10-02（金）15:00 - 16:00 | 株式会社STANDS

実施日時: 2026-10-02（金）15:00 - 16:00
形式: Slack完結型（会議を立てず、通常業務と並行）
シナリオ: 管理画面のログインレポートCSVダウンロード機能の不具合により、顧客が自分でダウンロードしたCSVに他社プロダクトのデータが混入していた（**架空の不具合です**）

この資料について

誰かの対応を評価するための資料ではありません。

今日の目的は「うまく対応できたか」を測ることではなく、**対応フローに何を書くべきかを洗い出すこと**でした。見つかった空白は、ルールが無かったことによるものです。
個人の判断の問題ではありません。

そのため、**うまくいった動きは名前を挙げて記録し、空白の指摘では名前を出していません。**

1. 数字で見る今回

測定項目	結果
第一報 → 最初の反応	**約2分**
第一報 → ISMS管理者に届くまで	**約10分**
「疑い」として調査・顧客連絡が決まるまで	約16分
CS → エンジニアへ調査依頼	17分
原因の特定（不具合の所在・発生期間）	29分
修正リリース完了（止血）	**48分**
社内対応用チャンネルの作成	**作られなかった**（既存3チャンネルに分散）
ハドル・通話の発生	**なし**（全編テキストのみ）
実システムへの接触	**なし**（ルールどおり）

初動は速く、**1時間以内に原因特定から修正リリースまで到達しています。**

2. よくできていたこと

初動が速い

第一報から**2分**で一次受けが反応し、**10分**で責任者へエスカレーションされました。
「確認します」で止めず、同時に社内へ展開できています。

止血が早い

「まずは出血を止めるのが最優先」という提起（武藤さん）から、**8分で修正リリース**まで
到達しました。調査と並行して修正を進める判断ができています。

影響範囲を自力で掘り下げた

誘導なしで、次の2段階に到達しました。

気づき	誰が
「同じ期間にダウンロードした5社とは何か。優先的に確認すべきでは」	宇野さん
「5社に加えて、その5社に自社情報を見られた可能性のある顧客も影響範囲」	武藤さん

後者は今回いちばん難しい論点です。**漏えいは「受け取った側」だけでなく
「見られた側」にも及ぶ**という構造に、短時間で到達しています。

対外対応の準備が自発的に始まった

依頼を待たずに、顧客周知メールの下書き（吉田さん）、影響顧客の確認シート（宇野さん）、
混入チェック用のスキル（宇野さん）が作られました。CS側の動き出しは速かったです。

ルールが守られた

- 顧客との共有チャンネルに社内の会話が流れたのは**1回のみ**。注意後は発生せず
- **実システムには誰も触っていません。**「確認してみます」という発言は出ましたが、
  ルールがあったため実行には至りませんでした

---

3. 見つかった空白

ここからが今回の成果です。**すべて「決まっていなかったこと」です。**

① 情報が3つのチャンネルに分散した

社内対応用のチャンネルは作られず、やり取りは**個人のtimes → CS-engineer → CSチャンネル**の
3か所、5スレッドに分かれました。終了後、**対応スレッドの一覧を作り直す作業**が発生しています。

なぜ問題か
全体像を持っている人がいなくなる。二重連絡や、回答の食い違いが起きる
あとから時系列を再構成できない。「知った時」の説明が、散らばった履歴の寄せ集めになる
必要な人が入らない／関係ない人を巻き込む

フローに書くこと: 第一報を受けた人が専用チャンネルをその場で立てる（許可を待たない）。
命名規則と、そこに何を集約するか。

② 証跡保全の指示が、誰からも出なかった

今回は修正を優先したため問題になりませんでしたが、実際には
「いつ・誰が・何をダウンロードしたか」のログが、影響範囲を確定する唯一の根拠になります。

調査のために本番を触れば、その操作自体もログに残ります。保全の指示が出ないまま調査が進むと、
根拠を求められた段階で出せるものがないという状態になります。

フローに書くこと: 何を保全するか（ダウンロード操作ログ・デプロイ記録・変更履歴）、
誰が指示するか、触る前に何を宣言するか。

③ 混入元の3社への連絡方針が決まらなかった

全社への周知メールと、CSVをダウンロードした5社への個別報告までは決まりました。
一方、**データの持ち主である3社への通知**は議題に上がらないまま時間切れとなっています。

ここは**報告義務を誰が負うかに直結**します。当社が3社から個人データの取扱いの委託を
受けている立場なら、3社への通知で当社の報告義務が免除され得ます。自ら取得した
個人情報という整理なら、当社が報告主体です。

フローに書くこと: 委託／自社取得の契約上の整理を、どこを見れば分かるようにするか。
「どの顧客との契約が、どちらの類型か」の一覧。

④ 機能を止める判断の権限が決まっていない

今回は修正が数分で完了したため停止は不要でした。ただし、**修正に時間がかかる場合、
不具合のある機能を一時的に止めるかどうか**は誰かが決めなければなりません。
その権限者が決まっていないため、今回は論点として浮上しませんでした。

フローに書くこと: 機能の一時停止を誰が決めるか。深夜・休日はどうするか。

⑤ 「個人情報に当たるか」の判断に幅があった

投票では **1（報告対象）が9名、2（対象外）が1名、3（判断できない）が1名**に割れました。
終了後の質疑でも「氏名以外の項目はどう扱うのか」「ユーザーID＋企業名は個人情報か」という
論点が続いています。

これは認識不足ではなく、**拠り所になる資料が社内に無い**ということです。

フローに書くこと: 当社が扱うデータの各項目について、個人情報に当たるかの整理。
特に**カスタムクエリ**は顧客が任意に値を入れる列であり、中身を把握していないと
漏えいした項目を当社が確定できません。

⑥ 顧客への連絡文面の型が無い

「今までは機能が使えないベースの障害報告だった。個人情報の漏えいになると、
いつものトーンでいいのか悩ましい」という発言がありました。

フローに書くこと: 第一報・続報・最終報告のテンプレート。誰が文面を承認するか。

⑦ 全編テキストのみで進んだ

会議は主催側から立てず、参加者からも立ちませんでした。記録の観点では理想的で、
判断の過程がほぼ全部 Slack に残っています（この報告書も、そのおかげで復元できました）。

一方、認識合わせが必要な論点ほど往復が増えます。実際に、影響範囲の確定と報告主体の判断は
時間内に収束しませんでした。

フローに書くこと: どの時点で音声に切り替えるか（例: 判断が割れたら、30分で収束しなければ）。
音声で決めたことを書き戻すルール。

⑧ エンジニアの対応が1名に集中した

調査の依頼は**エンジニア2名宛**に出されましたが、応答・原因特定・修正リリースまで、
実際に動いたのは**1名**でした。もう1名が入る流れにはなっていません。

今回のシナリオは「当事者が一人で調べて一人で抱える」ことを論点に含めていました。
その状況が、そのまま再現されたことになります。

なぜ問題か
その人が不在・多忙なら、調査が止まる。 今回の速さは一人の即応に依存していた
原因を作った可能性のある人が、一人で事実を確定することになる。 第三者の確認が入らない
修正と報告を同時に抱えることになり、**どちらかが薄くなる**
「2名宛に依頼した」だけでは2名体制にならない。**役割を分けないと一人に寄る**

フローに書くこと: 調査は2名以上で行う。**事実を出す役と、それを確認する役を分ける。**
誰が2人目を指名するか。1名しか確保できない場合にどうするか。

---

4. これから実施すること

1. 今日出た空白を統合し、**対応フローの目次**にします
2. 各項目に責任者と期限を割り当てます
3. 技術面の点検（集計クエリのプロダクト絞り込みのテスト整備・リリース前チェック・
   ダウンロード操作ログの保全）を、エンジニアチームのタスクとして別途起票します
   - **今回の不具合は架空のものです。**実際に起きた事象ではありません。
   ただし同じことが起こり得る箇所なので、未然の点検として扱います
4. 対応フローのドラフトができたら、**関係者のレビューで確認します**（訓練の再実施はしません）

アンケート（Googleフォーム）の回答も、この目次に反映します。**本日中にご協力ください。**

5. 補足

今回の設定について

設定	理由
進行役（空）は「休暇で不在」	シナリオを知っている人が対応に入ると、他の人の判断が観測できないため。普段この対応に入る人が抜けた状態で回るかを見る目的も兼ねています
ISMS管理者にも事前共有なし	全員を訓練の対象にするため
会議を主催側から立てない	実際のインシデントは通常業務中にSlackで始まるため。通知に気づくか、片手間で初動が回るかは、会議ありの訓練では測れません

最後に

当社は無罰ルールです。 誤送信や誤設定をした本人を責めません。
隠されることのほうが、会社にとって圧倒的に危険だからです。

実際に何かやってしまったときは、隠さず、すぐ言ってください。
早く言うほど被害が小さくなります。それだけです。

個人情報漏えい 机上訓練 参加者配布資料

訓練で扱った論点の解説と、押さえておきたい法令の要点

参加者へ配布可 ／ 訓練終了後　実施日 2026-10-02（金）15:00 - 16:00　株式会社STANDS

配布タイミング: 訓練終了後
シナリオ: 管理画面の**ログインレポートCSVダウンロード機能**の不具合により、顧客が自分でダウンロードしたCSVに他社プロダクトのデータが混入していた

お疲れさまでした。訓練で扱った論点の解説と、押さえておきたい法令の要点をまとめています。
今日決められなかったことは、これから作る対応フローに反映します。

1. シナリオの全体像

時点	起きたこと
第一報	取引先A社から「管理画面からダウンロードした**ログインレポート**のCSVに、弊社のユーザーではないデータが含まれている」と連絡
原因判明	**ログインレポート**の**集計クエリでプロダクトIDの絞り込みが一部効いていなかった。**先月のリリースから入っていた不具合。CSVは約48,000行
規模判明	混入は他社プロダクト**3件分・ユニークユーザー1,240名。**含まれるのは氏名・ユーザーID・uuid・IPアドレス・ユーザーエージェント・リファラ（閲覧画面）・カスタムクエリ・所属企業名など。**同じ期間に同じレポートを取得した顧客は計5社**
二次拡散	A社が社内共有フォルダに保存しており、**10名程度が閲覧可能な状態**だった。ダウンロード有無は確認中

> **この資料での呼び方**: 情報が漏えいした当人（今回は3社のエンドユーザー1,240名）を**「該当者」**と呼びます。個人情報保護法では**「本人」**と呼ばれており、法令や委員会への報告様式ではそちらの表記が使われます。

現実に起こりうる形にしています。**顧客が自分で操作してデータを取得できる機能**であること、**不具合はリリースを通じて全顧客に配られている**ことが、このシナリオの肝です。
一人のミスではなく、**気づかないうちに全顧客が同じ地雷を踏める状態になっていた**という構図です。

2. 各場面の論点と、正解に近い動き

場面① 第一報を受けたとき

論点	正解に近い動き
これはインシデントか、問い合わせか	**「漏えいの疑い」として扱う。** 確証を待たない。誤報でよい
誰に上げるか	一次受けは自分で判断せず、**即座にISMS管理者（藤原さん）へ。**技術的な確認より先
A社に何と返すか	**「そのファイルを削除せず、これ以上共有しないでお待ちください」**
何を記録するか	**受信日時（分単位）**、連絡してきた人、原文そのまま
社内はどこで動くか	**専用チャンネルをその場で立てる。** 第一報を受けた人が作ってよい（許可を待たない）

> **やりがちな失敗**: 「すぐ削除してください」と即答してしまう。
> 親切のつもりでも、**何が漏れたかを調べる唯一の証拠が消えます。**
> 削除は、こちらで中身を特定し、削除証明の取り方を決めてから依頼します。

場面② 原因を調べるとき

論点	正解に近い動き
誰が調査するか	改修した本人を一人にしない。**必ず2名以上。**本人は事実を出す役、別の人が確認する役
止血	**不具合は今この瞬間も生きている。** ダウンロード機能を止めるかを最初に判断する。誰が決めるかを含めて
本番環境の扱い	調査のための操作もログに残る。**触る前に、何のために何を見るかを宣言してから触る**
保全すべき証跡	**管理画面のダウンロード操作ログ**（誰がいつ何を取得したか） / 該当リリースのデプロイ記録 / 集計クエリの変更履歴 / A社が取得したCSVの現物 / 該当期間のDBログ
範囲の確定	**いつから不具合が入っていたか**と、**その間に誰がダウンロードしたか**の2つが揃って初めて件数が出る

> **やりがちな失敗**: 指摘してきた1社の件だけを見て終わる。
> **プロダクトの不具合は、リリース以降のすべての利用者が対象になり得ます。**
> ダウンロードの操作ログが残っていなければ、**範囲を確定できないまま報告することになります。**

場面③ 規模と中身が判明したとき（最重要）

論点	正解に近い動き
件数の数え方	**行数ではなく「該当者の数」**（法律上の「本人の数」）。48,000行ではなく **1,240名**
何が漏れたかの特定	**カスタムクエリは顧客が任意に埋める列。**メールアドレスや社員番号を入れている顧客がいれば、漏れた項目は当社の想定を超える。**まず中身を確認する**
取引先名の露出	ユーザーグループ名には**顧客企業名**が入る。個人情報ではないが、他社に見えた時点で取引先の存在が漏れている（守秘義務）
報告義務	1,000人超に該当する可能性が高い。**「報告対象になり得る」前提で動き始める**
報告主体	**契約上の立て付けで変わる**（次章参照）。まず契約書を確認する
該当者への通知	**当社は該当者の連絡先（メールアドレス）を持っていない。**氏名とIDだけ。**通知は3社経由でしか成立しない。**誰がいつ依頼するかを決める
3社への連絡	**最優先。** 他ルートで知られると信頼の毀損が桁違いに大きくなる

> **やりがちな失敗**:「1,000人以下だから報告義務なし」で止まる。
> 法律上の報告義務がなくても、**委託契約・NDA・SLA上の通知義務は別に存在します。**
> 「法的義務なし ＝ 何もしなくていい」ではありません。

場面④ 二次拡散が判明したとき

論点	正解に近い動き
削除の確認方法	口頭・チャットの「消しました」では不十分。**書面（メール可）で、削除日時・対象・確認者を残してもらう**
ダウンロード有無	A社側のログで確認可能か依頼する。確認できない場合は**「確認できなかった」と記録する**（曖昧にしない）
「知った時」の起点	法定期限の起算点。**組織として一つに決めて記録する**

---

3. 押さえておきたい法令の要点

> 以下は訓練用の整理です。**実際の判断は必ず法務／顧問弁護士に確認してください。**

個人情報保護委員会への報告義務

個人情報保護法では、以下の**いずれか**に当たる漏えい等（**そのおそれを含む**）が発生した場合、
個人情報保護委員会への報告義務が生じます。

#	類型	今回のシナリオ
1	要配慮個人情報が含まれる	該当しない
2	不正に利用されると財産的被害が生じるおそれがある（クレジットカード番号等）	該当しない
3	不正の目的をもって行われたおそれがある（不正アクセス・ランサムウェア等）	該当しない（過失による誤抽出のため）
4	**該当者（法律上の「本人」）の数が1,000人を超える**	**該当する可能性が高い（1,240名）**

重要な点が2つあります。

- **「おそれ」で足りる。** 漏えいが確定していなくても、疑いの段階で報告対象になり得ます。
  だからこそ初動は「確証を待たずに動く」が正しいのです。
- **数えるのは該当者の数。** レコード数ではありません。

報告の期限

種別	期限
速報	「知った時」から**速やかに**（概ね3〜5日以内）
確報	「知った時」から**30日以内**（上表の類型3「不正の目的」の場合は60日以内）

「知った時」がすべての起点です。だから訓練で時刻の記録にこだわりました。
第一報を受けた時刻を残していないと、期限の計算ができません。

該当者への通知

該当者（法律上の「本人」）への通知も原則として必要です。
通知が困難な場合は、該当者の権利利益を保護するために
必要な代替措置（公表など）を講じることで代えられます。

委託を受けている場合の扱い（今回いちばん重要な論点）

当社が3社から個人データの取扱いの委託を受けている立場なのか、
当社が自ら取得した個人情報なのかで、報告主体が変わります。

立て付け	報告主体
当社が3社から**委託を受けて**取り扱っている	委託元である3社が報告義務を負う。**当社は3社へ通知することで、当社自身の報告義務が免除され得る**
当社が**自ら取得した**個人情報	**当社が報告主体**

この整理は、事故が起きてから契約書を探していては間に合いません。
速報は「知った時」から数日以内です。その時間を契約書の確認に使うことになります。

今日この場で答えが出たかどうかにかかわらず、確かめたいのは次の2点です。

問い	なぜ
誰でも答えられる状態か	特定の人が知っているだけなら、その人が不在の日には答えが出ない
どこを見れば分かるか言えるか	「調べれば分かる」と「すぐ出せる」は別物。置き場所が決まっているかどうか

> **アクション**: 契約上の立て付けを整理し、すぐ参照できる場所に置く。
> 「どの顧客との契約が、どちらの類型か」の一覧が必要です。

---

4. 誤送信・誤抽出インシデントでやりがちな失敗

#	失敗	なぜ起きるか
1	**良かれと思って即座に削除を依頼する**	相手を待たせたくない心理。結果として証拠が消える
2	**確証を得てから報告しようとする**	「まだ確実じゃないので」。初動が数日遅れる
3	**当事者が一人で調べて一人で抱える**	責められると思うから。**当社は無罰ルールです**
4	**レコード数を漏えい件数として報告してしまう**	直感的に行数を数えてしまう。数えるのは該当者の数
5	**時刻を記録していない**	対応に必死で記録が後回しになる。法定期限の起点が失われる
6	**指摘してきた1社だけ見て、他の利用者を確認しない**	不具合はリリースを通じて全顧客に配られている
7	**顧客との共有チャンネルで社内調整を始めてしまう**	全員リモートでSlackが主戦場。Slack Connectでは相手に全部見える
8	**重要な判断をDMで決めてしまう**	リモートでは自然な動き。しかし記録が残らず、後から追えない

---

5. 明日から全員にお願いしたい5つのこと

① 「疑い」の段階で上げてください

確証は要りません。「なんかおかしい気がする」で構いません。
誤報を許容します。 遅れることのほうがはるかに高くつきます。

② 時刻をメモしてください

「何時何分に、誰から、何を聞いたか」。スクリーンショットでもSlackのリンクでも構いません。
これが法定報告の起点になります。

③ インシデント専用のチャンネルを立てて、そこに集めてください

今回の訓練では専用チャンネルが作られず、やり取りが
顧客との共有チャンネル・既存の社内チャンネル・DM・スレッドに分散しました。

これは誰かの判断ミスではありません。**「作る」という決まりが無かっただけ**です。
ただ、そのままだと実際のインシデントで次のことが起きます。

分散すると起きること	なぜ困るか
全体像を持っている人がいなくなる	誰が何を知っているかがバラバラになり、二重連絡や矛盾した回答が出る
あとから時系列を再構成できない	「知った時」や経緯の説明は、**散らばった履歴をかき集めて作ることになります**
顧客との共有チャンネルに社内の相談が流れる	Slack Connect では**相手に全部見えています**
関係ない人を巻き込む／必要な人が入らない	既存チャンネルでは、対象者を絞れません

お願いしたいこと

- **第一報を受けた人が、その場で専用チャンネルを立てる。** 許可を待つ必要はありません
- 名前は `incident-{日付}-{短い件名}` のように、ひと目でそれと分かるものにする
- 調査・判断・対外文面の検討は、**すべてそこに集約する**
- 顧客との共有チャンネルは、**顧客への連絡だけ**に使う
- **迷ったら作ってください。** 空振りでも、あとでアーカイブすれば済みます

④ 重要なやり取りは、DMではなくチャンネルに残してください

全員リモートなので、つい個別のDMで話が進みます。しかし**DMで決まった判断は記録に残らず、
後から「誰がいつ何を決めたか」を追えません。** 法定報告や監査の場面でこれが致命傷になります。

- ハドルや通話で決めたことは、**必ずSlackに書き戻す**
- DMを使うときは、**先にチャンネルへ「〇〇さんにDMします」と書く**

⑤ 隠さないでください

当社は無罰ルールです。 誤送信や誤抽出をした本人を責めません。
隠されることのほうが、会社にとって圧倒的に危険だからです。
早く言うほど被害が小さくなります。それだけです。

---

6. この訓練の後に実施すること

1. 今日出た「決められなかったこと」を統合し、**対応フローの目次**にします
   - 少なくとも**専用チャンネルの命名規則と、誰が立てるか**はフローに明記します（今回、作られなかったため）
2. 各項目に責任者と期限を割り当てます
3. 技術面の点検（集計クエリのプロダクト絞り込みのテスト整備・リリース前チェック・ダウンロード操作ログの保全）を、エンジニアチームのタスクとして別途起票します
   - **今回の不具合は架空のものです。** 実際に起きた事象ではありません。
   ただし**同じことが起こり得る箇所**なので、未然の点検として扱います

4. 対応フローのドラフトができたら、**関係者のレビューで確認します**（訓練の再実施はしません）
   - 今日詰まった箇所が、ドラフトを読めば解消されるかを机上で確かめます
